CASE STUDY

The Zero-Day Trade and Its Fallout: The Events in This Is How They Tell Me the World Ends

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Defenders, researchers, journalists and the people who were targeted have spent fifteen years piecing together how software flaws became a traded commodity, and what happened when the stock escaped. Nicole Perlroth's 2021 book *This Is How They Tell Me the World Ends: The Cyberweapons Arms Race* tells that story as narrative [2]. This study does something narrower. It takes the events that the book's reviewers and publisher say it covers, and checks each one against the primary record: vendor advisories, lab reports, court filings, indictments, government statements and the CISA Known Exploited Vulnerabilities (KEV) catalog.

The book itself was not opened for this study. Nothing below says what the book claims unless a review or the publisher says so, and those statements are graded **Reported** and attributed by name. What the study can show is the record underneath the book's events, which is unusually rich.

That record has five threads. A **market** formed in the open, with bug bounties from 2005 and published broker prices of a million dollars for an iPhone chain by 2015 [11] [12]. **Operation Aurora** in 2009 and 2010 was followed by Google's paid bug rewards and, in 2014, Project Zero [85] [91] [95]; reading that as cause and effect is this study's inference (**Inferred**). Two **leaks of offensive tooling** put exploits in public hands: the Hacking Team breach in July 2015, which released Flash zero-days that were exploited in the wild that month [18] [20], and the Shadow Brokers releases of 2016 and 2017, the second of which carried the SMB exploit later used in WannaCry and NotPetya [56] [57] [60]. **Commercial spyware**, above all NSO Group's Pegasus, was documented phone by phone by Citizen Lab, Amnesty International, Lookout and Google Project Zero from 2016 to 2021 [13] [35] [39] [41]. Finally, governments answered with **policy and law**: the Vulnerabilities Equities Policy charter, Entity List designations, an executive order on spyware, Treasury sanctions, and lawsuits by WhatsApp and Apple [28] [42] [45] [47] [48] [103].

> Evidence grade: the technical facts, dates and official actions are **Confirmed** from primaries. The NSA origin of the Shadow Brokers tools is **Reported**: Microsoft says so, but the US government briefing declined to name a source [67] [71]. Market prices beyond Zerodium's own page are **Reported** [13] [14]. The book's disputed claims (Baltimore and EternalBlue, the Bezos phone) are **Reported** on both sides, and the court record on Baltimore is set out in Part 9.

Key facts at a glance

Field	Value
The book	*This Is How They Tell Me the World Ends: The Cyberweapons Arms Race*, Nicole Perlroth, Bloomsbury, 9 February 2021, 528 pp. [2] [1]; 2021 FT and McKinsey Business Book of the Year [3]; listed twice in the library's book list [4]
Book status in this study	Not opened. Coverage of events comes from two reviews and the publisher (**Reported**) [2] [5] [6]
Earliest dated event in scope	Equation group command-and-control domains registered as early as 1996; earliest samples compiled in 2002 [49]
Open market	Zero Day Initiative founded 2005, over 15,000 vulnerabilities disclosed since 2007 [11]; Zerodium's public USD 1,000,000 bounty per iOS 9 chain, closing 31 October 2015 [12]
Aurora	Google detected the intrusion in mid-December 2009 and disclosed it on 12 January 2010 [85]; CVE-2010-0249 fixed in MS10-002 on 21 January 2010 [88]; ATT&CK `G0066` Elderwood [96]
Hacking Team leak	Made public 5 July 2015 [18]; about 400 GB [25]; Flash CVE-2015-5119, CVE-2015-5122 and CVE-2015-5123 exploited in the wild in July 2015 [20]
Shadow Brokers	First appeared 13 August 2016 [50]; Windows archive released 14 April 2017 (US time) [57] [59]; MSRC mapped the exploits to MS17-010 and four older bulletins [60]
EternalBlue	CVE-2017-0144, patched 14 March 2017 in MS17-010 [56]; NVD CVSS v3.1 8.8, no CWE assigned [61]
WannaCry	12 May 2017 [63]; about 300,000 computers in at least 150 countries per Treasury [69]; attributed to North Korea on 19 December 2017 [71] [72]
NotPetya	27 June 2017 via the M.E.Doc updater [74]; charged against six GRU Unit 74455 officers [78]; home study is SANDWORM_OPERATIONS.md
Pegasus	Trident chain against Ahmed Mansoor, August 2016 [13]; FORCEDENTRY zero-click, CVE-2021-30860, fixed in iOS 14.8 on 13 September 2021 [39] [40]
Policy record	VEP charter 15 November 2017 [103]; Entity List 4 November 2021 [45]; EO 14093 signed 27 March 2023 [47]; Intellexa sanctions 5 March 2024 [48]
Courts	Ninth Circuit affirmed denial of NSO's immunity defense, 8 November 2021 [28]; Supreme Court denied certiorari, 9 January 2023 [29]
ATT&CK record	Groups `G0066`, `G0020`, `G0022`, `G0032`, `G0034`, `G0038`; software `S0366`, `S0368`, `S0606`, `S0203`, `S0047`, `S0182`, Mobile `S0289` and `S0316`; 62 Enterprise technique rows in Part 12

Key findings

- **The market was never hidden.** Zerodium posted its iOS 9 price and rules on its own site [12], and the Zero Day Initiative published its purpose and counts [11] (**Confirmed**). Specific private sales, such as a reported Zerodium purchase in November 2015 and Pegasus license prices, rest on secondary reporting [13] [14] (**Reported**).
- **Leaked exploits were used fast.** The Hacking Team Flash bugs went public on 5 July 2015 and were exploited in the wild that month [18] [20]. The Windows SMB exploits went public on 14 April 2017 and WannaCry used one 28 days later [57] (**Confirmed**).
- **The patch came before the leak, and the damage came after.** Microsoft fixed the SMBv1 flaws 31 days before the Shadow Brokers' Windows release [56] [60]. WannaCry still hit NHS machines that ran unpatched or unsupported Windows [68] (**Confirmed**); NotPetya spread mainly by stolen credentials, so patching alone did not protect against it [78] (**Confirmed**). The "NSA cyberweapon" framing implies novelty that the patch record does not support (**Inferred**).
- **EternalBlue was not the whole story of NotPetya.** The GRU indictment says NotPetya spread by credential theft first and used EternalBlue or EternalRomance only when those methods failed [78] (**Confirmed**), and ESET says the SMB exploit was aimed only at the local address space [119] (**Confirmed**).
- **The court record on Baltimore does not mention EternalBlue.** The Robbinhood indictment describes generic hacking tools and administrator accounts [108] (**Confirmed**). Graham says the book conceded the point while defending the original reporting [7]; Howard reads the book as claiming only that Microsoft analysts found EternalBlue evidence on the networks [5] (**Reported**). Absence from an indictment is not proof of a negative (**Inferred**).
- **Spyware abuse was documented by evidence, not leaks alone.** Citizen Lab, Amnesty and Project Zero captured exploits and infection traces on real phones: Trident in 2016, KISMET in 2020, FORCEDENTRY and Megalodon in 2021 [13] [34] [35] [39] (**Confirmed**).
- **Governments moved from statements to sanctions.** The VEP charter in 2017 [103], Entity List additions in 2021 [45] [46], EO 14093 in 2023 [47] and OFAC designations in 2024 [48] each went further than the last (**Confirmed** for each action; that each went further than the last is **Inferred**).
- **ATT&CK does not carry the leak.** There is no ATT&CK object for EternalBlue, DoublePulsar or the Shadow Brokers, and the `G0020` Equation page does not mention them [114] [81] (**Confirmed**). ATT&CK records the exploits only as `T1210` procedure text, on WannaCry, NotPetya and Bad Rabbit and on several later groups and tools (among them TrickBot, Wizard Spider and Ember Bear) [80] [79] [111] [112].

Top recommendations

1. **Patch remotely reachable services on a clock, and track KEV.** MS17-010 was available 59 days before WannaCry [57]. Every MS17-010 CVE is now in KEV with known ransomware use [22] [23]. Map this to ATT&CK `M1051` Update Software and D3FEND Software Update (Part 12).
2. **Remove legacy protocols rather than defend them.** Disable SMBv1, as the MS17-010 workaround and US-CERT advised [56] [64]. Windows 10 1709 and later, Server 2019 and Windows 11 no longer install it by default [120].

3. **Block SMB at the boundary and segment inside.** TA17-132A advised blocking the SMB ports at the network edge [64]; NotPetya reached non-Ukrainian victims over VPN links into Ukraine [119]. Use D3FEND Network Traffic Filtering and ATT&CK `M1030` Network Segmentation.
4. **Treat a vendor update channel as an attack path.** NotPetya arrived through backdoored M.E.Doc updates on three dates [118]. Inventory software and verify updates (D3FEND Software Inventory, Software Update; CAPEC-186).
5. **Keep offline backups.** US-CERT said NotPetya victims were unlikely to recover even after paying [75], and WannaCry payers do not appear to have been able to decrypt [57]. Plan restores (D3FEND Restore File, Restore Software).
6. **Give at-risk staff a mobile forensics path.** Amnesty released the Mobile Verification Toolkit and about 700 Pegasus domains [35]; Apple and Citizen Lab fixes followed captures on real phones [15] [40]. Patch mobile OS releases promptly and know who to call.

Scope and method

This study covers the events that the book's reviewers and publisher associate with it, from the earliest Equation infrastructure (1996) through the spyware sanctions of 2024 and the Robbinhood plea of 2025. It follows the method in the case studies README: primary sources first, every claim graded, numbers given as the source states them. Every source in the Sources table was opened on 3 November 2026. Where a primary could not be opened (the book itself, the New York Times Baltimore story, the FTI report on the Bezos phone, the Shadow Brokers' own posts, a Symantec post now returning 404, and two DOJ pages behind a bot check), the study says so and grades the claim on what was opened. Direct quotations are kept under 15 words.

Home rule for overlapping events: Stuxnet detail lives in /case-studies/STUXNET.md, SolarWinds in /case-studies/SOLARWINDS_SUNBURST.md, and NotPetya and the Ukraine grid attacks in /case-studies/SANDWORM_OPERATIONS.md. Each gets one summary paragraph here. This study is the home for the zero-day market, Aurora, the Hacking Team and Shadow Brokers leaks, WannaCry, NSO Group and Pegasus, and the Baltimore reporting dispute. The actor view of the Equation platform and of what the leaks say about their makers lives in United States-Attributed Threat Actors; this study follows the leaked exploits downstream.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the vendor or lab that did the analysis, a government agency, a court record, the KEV catalog, or the MITRE page itself
Reported	Stated only in journalism, a review, a publisher's copy, or a secondary source relaying another party; the original was not opened or does not exist publicly
Demonstrated	A public reproduction exists that others can check (the RiskSense EternalBlue code, Part 6)
Inferred	The study's own reasoning from Confirmed facts, labelled as such

Part 1: the book and what this study can say about it

1.1 The record of the book

Bloomsbury published the book on 9 February 2021 (528 pp.), ebook ISBN 9781635576061 [2]; Open Library lists the hardcover as ISBN 9781635576054 [1] (**Confirmed**). It won the 2021 FT and McKinsey Business Book of the Year [3] (**Confirmed**). Bloomsbury also lists a bronze Arthur Ross Book Award medal from the Council on Foreign Relations, recorded here through the publisher only [2] (**Reported**).

The publisher frames the book as resting on years of reporting and hundreds of interviews, and casts the United States as the dominant hoarder of zero-days that lost control of its hoard and of the market [2]. That is the publisher's framing, not a finding (**Reported**). The library's book list carries it twice, describing it as covering the zero-day market, the NSA, Vupen and Zerodium [4] (**Confirmed** that the list says so).

1.2 What the reviews say it covers

Two reviews were opened. Rick Howard's Cybersecurity Canon review lists Project Gunman (1984), the 2010 Chinese intrusion into Google, NSO Group and Pegasus, EternalBlue, WannaCry, NotPetya, and an exchange with the exploit developer Ivan Arce [5] (**Reported**). Jean Navedo's review for American University's School of International Service says the book opens in Kyiv and covers Russian attacks on Ukraine, the Snowden leaks of 2013, an early exploit black market with US agencies as the top buyers, Stuxnet, the broker market that followed it, the Shadow Brokers leaks of 2016 and 2017, Russian and Iranian attacks, interviews with brokers, and travel to Argentina [6] (**Reported**).

This study takes those events as its scope. Project Gunman, the Snowden material, Vupen and the Argentina reporting have no primary in this pass, so they are named here and not studied (**not checked**).

1.3 How claims are graded against the book

A book is a secondary source. Where the primary record exists, this study cites it and the grade comes from the primary. Where only the book makes a claim, the claim would be **Reported** and attributed to the book by title and author; since the book was not opened, no such claim is made. Where a reviewer characterizes what the book says, the reviewer is named.

Part 2: the timeline

Date	Event	Grade	Sources
1996	Some Equation group command-and-control domains registered	Confirmed	[49]
2002	Earliest Equation samples compiled	Confirmed	[49]
2005	Zero Day Initiative established to reward researchers and route zero-days privately to vendors	Confirmed	[11]
November 2008	Earliest Stuxnet components in use (home: STUXNET.md)	Confirmed	[98]
Mid-December 2009	Google detects a targeted attack from China on its corporate infrastructure	Confirmed	[85]
15 December 2009 to 4 January 2010	Aurora attacks run until the C2 servers shut down, per McAfee quoted in the press	Reported	[89]
2 January 2010	Adobe discovers it was also targeted, per the press	Reported	[89]
11 January 2010	Symantec identifies Hydraq, per the press	Reported	[89]
12 January 2010	Google discloses the intrusion and says it will stop censoring Google.cn	Confirmed	[85]
14 January 2010	Microsoft Security Advisory 979352 for the IE flaw	Confirmed	[87]
15 January 2010	NVD publishes CVE-2010-0249; advisory v1.1 adds DEP as a mitigating factor	Confirmed	[86] [87]
21 January 2010	MS10-002 fixes CVE-2010-0249; Secretary Clinton asks China for a transparent review	Confirmed	[88] [90]
28 January 2010	Chromium launches a vulnerability reward program, USD 500 base and 1,337 for severe bugs	Confirmed	[91]
22 March 2010	Google redirects Google.cn users to Google.com.hk	Confirmed	[92]
2010	Stuxnet discovered	Confirmed	[98]
1 November 2010	Google extends rewards to its web properties	Confirmed	[93]
2012	Shamoon wiper first used by the Cutting Sword of Justice	Confirmed	[102]
28 May 2012	Kaspersky discloses Flame	Confirmed	[99]
5 June 2012	Google begins warning users targeted by state-sponsored attackers	Confirmed	[94]
11 June 2012	Kaspersky links Stuxnet's 2009 Resource 207 to Flame	Reported (vendor kinship claim)	[100]
17 February 2014	Citizen Lab maps Hacking Team RCS servers to 21 suspected government users	Confirmed	[16]
March 2014	Trojanized Qatif Today app delivers an Android RCS implant	Confirmed	[17]

Date	Event	Grade	Sources
28 April 2014	White House says it had no prior knowledge of Heartbleed	Confirmed	[110]
24 June 2014	Citizen Lab publishes the Android implant analysis	Confirmed	[17]
15 July 2014	Google announces Project Zero	Confirmed	[95]
September 2014	Kaspersky detects Equation malware and classified-marked documents on a US home computer	Confirmed (Kaspersky's account)	[54]
16 February 2015	Kaspersky names the Equation group	Confirmed	[49]
5 July 2015	Hacking Team breach becomes public; CVE-2015-5119 and CVE-2015-5122 made public	Confirmed	[18] [19]
8 July 2015	WikiLeaks publishes more than 1 million Hacking Team emails	Confirmed	[24]
14 July 2015	MS15-077 fixes CVE-2015-2387, exploited in limited targeted attacks	Confirmed	[21]
6 August 2015	Citizen Lab summarizes what the leak confirmed	Confirmed	[25]
25 to 31 October 2015	Zerodium's iOS 9 bounty page archived; offer open until 31 October	Confirmed	[12]
November 2015	Zerodium reportedly acquires an iPhone chain for USD 1 million	Reported	[13]
March 2016	Buckeye (APT3) uses a DoublePulsar variant delivered by Bemstour, per Symantec	Confirmed (Symantec's account)	[117]
March 2016 onward	Russian government actors target energy and other sectors (TA18-074A)	Confirmed	[104]
10 and 11 August 2016	Ahmed Mansoor receives SMS lures to NSO infrastructure	Confirmed	[13]
13 August 2016	Shadow Brokers appear, claiming Equation Group files	Confirmed	[50]
15 August 2016	Cisco alerted to the posting	Confirmed	[51]
16 August 2016	Kaspersky ties the dump to Equation code with high confidence	Confirmed	[50]
17 August 2016	Cisco publishes CVE-2016-6366 (EXTRABACON); Fortinet publishes FG-IR-16-023	Confirmed	[51] [52] [53]
19 August 2016	Cisco addresses BENIGNCERTAIN on legacy PIX	Confirmed	[52]
24 August 2016	Citizen Lab and Lookout publish Trident and Pegasus	Confirmed	[13] [14]
25 August 2016	Apple ships iOS 9.3.5	Confirmed	[15]
February 2017	WannaCry Version 0 runs, spreading with stolen credentials	Confirmed (affidavit)	[57]

Date	Event	Grade	Sources
14 March 2017	Microsoft publishes MS17-010	Confirmed	[56]
8 April 2017	Public mirror of the decrypted first auction archive created	Confirmed (repository metadata)	[58]
14 April 2017 (US time)	Shadow Brokers release the Windows archive; first backdoored M.E.Doc update	Confirmed	[57] [59] [118]
15 April 2017	MSRC publishes its triage of the release	Confirmed	[60]
18 and 21 April 2017	RiskSense analyst publishes research on the exploit	Confirmed (affidavit)	[57]
9 May 2017	RiskSense releases reverse-engineered EternalBlue code	Demonstrated	[57]
12 May 2017	WannaCry Version 2 spreads with the SMB worm; the kill-switch domain is registered	Confirmed	[63] [64] [65]
13 May 2017	Microsoft ships fixes for XP, Windows 8 and Server 2003	Confirmed	[66]
14 May 2017	Microsoft's president says the exploits were stolen from the NSA	Confirmed (Microsoft's claim)	[67]
15 May 2017	Kaspersky reports the WannaCry and Lazarus code overlap	Confirmed	[70]
15 May and 22 June 2017	Further backdoored M.E.Doc updates	Confirmed	[118]
19 June 2017	Citizen Lab documents NSO SMS lures against Mexican journalists and lawyers	Confirmed	[31]
27 June 2017	NotPetya	Confirmed	[74] [78]
30 June 2017	ESET attributes the outbreak to TeleBots	Confirmed	[119]
1 July 2017	US-CERT TA17-181A	Confirmed	[75]
2017	Bad Rabbit (the S0606 page dates it to 2017; its earliest cited report is dated 24 October 2017)	Confirmed	[112]
27 October 2017	UK National Audit Office report on WannaCry and the NHS	Confirmed	[68]
15 November 2017	US publishes the Vulnerabilities Equities Policy charter	Confirmed	[103]
16 November 2017	Kaspersky publishes its investigation of the 2014 detection	Confirmed	[54]
19 December 2017	US and UK attribute WannaCry to North Korea	Confirmed	[71] [72]
15 February 2018	US and UK attribute NotPetya to the Russian military	Confirmed	[76] [77]
15 March 2018	TA18-074A	Confirmed	[104]
8 June 2018	Complaint against Park Jin Hyok filed	Confirmed	[57]
18 September 2018	Citizen Lab's Hide and Seek: Pegasus in 45 countries	Confirmed	[32]

Date	Event	Grade	Sources
1 October 2018	Citizen Lab: Omar Abdulaziz infected	Confirmed	[33]
6 October 2018	Pegasus installed on Hatice Cengiz's phone, four days after Jamal Khashoggi's murder, per Amnesty	Confirmed (Amnesty's finding)	[37]
12 March 2019	CVE-2019-0703 patched	Confirmed	[117]
3 to 7 May 2019	Robbinhood conspirator holds access to Baltimore networks and deploys ransomware	Confirmed (indictment)	[108]
14 May 2019	CVE-2019-3568 (WhatsApp VOIP stack) published	Confirmed	[27]
25 May 2019	NYT story ties Baltimore to EternalBlue (page not opened)	Reported	[8] [10]
13 September 2019	Treasury sanctions cite WannaCry figures	Confirmed	[69]
October 2019	WhatsApp sues NSO	Confirmed	[28]
28 January 2020	Graham disputes the Bezos forensic report	Reported	[9]
July and August 2020	36 Al Jazeera staff phones hacked with KISMET	Confirmed	[34]
October 2020	Six GRU officers indicted for NotPetya and other attacks	Confirmed	[78]
12 November 2020	Election infrastructure councils call 2020 the most secure election	Confirmed	[105]
8 December 2020	Indictment of Jon Chang Hyok, Kim Il and Park Jin Hyok returned	Confirmed	[73]
13 December 2020	CISA ED 21-01 on SolarWinds Orion (home: SOLARWINDS_SUNBURST.md)	Confirmed	[106] [107]
9 February 2021	The book is published	Confirmed	[2]
February 2021	FORCEDENTRY in use from at least this month	Confirmed	[39]
27 and 28 February 2021	Robert Graham's two critiques of the book	Reported	[7] [8]
13 to 15 July 2021	Microsoft patches the Candiru privilege escalations; Citizen Lab exposes Candiru	Confirmed	[38]
July 2021	Megalodon compromises a fully patched iPhone 12 on iOS 14.6	Confirmed	[35]
18 July 2021	Pegasus Project and Amnesty's forensic methodology	Confirmed	[35] [36] [37]
13 September 2021	FORCEDENTRY report; iOS 14.8	Confirmed	[39] [40]
3 November 2021	KEV catalog launches with CVE-2021-30860, CVE-2017-0143 and the Candiru CVEs	Confirmed	[22] [38]
4 November 2021	NSO, Candiru, Positive Technologies and a Singapore firm added to the Entity List	Confirmed	[45] [46]
8 November 2021	Ninth Circuit rules against NSO on immunity	Confirmed	[28]

Date	Event	Grade	Sources
23 November 2021	Apple sues NSO Group	Confirmed	[42]
15 December 2021	Project Zero publishes its FORCEDENTRY analysis	Confirmed	[41]
2022	KEV adds the Flash, Trident, WhatsApp and the other five MS17-010 CVEs (dates in Part 11)	Confirmed	[22]
9 January 2023	Supreme Court denies NSO's petition	Confirmed	[29]
27 March 2023	EO 14093 signed	Confirmed	[47]
5 March 2024	OFAC designates Intellexa and Cytrox	Confirmed	[48]
4 April 2024	Robbinhood indictment filed	Confirmed	[108]
6 May 2025	Meta reports a jury verdict against NSO	Reported	[30]
27 May 2025	Robbinhood plea; Baltimore losses over USD 19 million	Confirmed	[109]
20 May 2026	KEV adds CVE-2010-0249 (Aurora) and CVE-2008-4250 (MS08-067)	Confirmed	[22]

Part 3: the market

3.1 Bounties in the open

The Zero Day Initiative says it was set up in 2005 to reward researchers and route zero-days privately to the affected vendors, and reports more than 15,000 vulnerabilities disclosed since 2007 and more than 35 Pwn2Own events [11] (**Confirmed**). The page does not mention its TippingPoint origin, so this study does not state it.

Google followed with its own programs. Chromium's reward program launched on 28 January 2010 with a USD 500 base and USD 1,337 for severe or clever bugs [91]; Google extended rewards to its web properties on 1 November 2010 [93] (**Confirmed**). Both came weeks and months after Aurora (Part 4).

3.2 The broker price list

Zerodium's own page, preserved in an archived copy dated 25 October 2015, offered USD 1,000,000 per exclusive browser-based, untethered iOS 9 jailbreak, USD 3,000,000 in total, open until 31 October 2015 [12] (**Confirmed**). A qualifying chain had to bypass ASLR, the sandbox, rootless, code signing and the bootchain [12]. That list is a fair summary of what a modern mobile exploit chain must defeat (**Inferred**).

Citizen Lab, citing others, reports that Zerodium acquired a similar iPhone chain for one million dollars in November 2015, and that one-click remote iPhone jailbreaks fetch hundreds of thousands up to a million dollars [13]. Zerodium did not publish the purchase (**Reported**). Lookout, citing news reports, says Pegasus averaged more than USD 25,000 per target and that NSO once sold 300 licenses for USD 8 million [14] (**Reported**).

Meta reports that testimony in the WhatsApp case showed NSO spending tens of millions of dollars a year on installation methods [30]. The docket was not opened and the page gives no figures, so none are stated here (**Reported**).

3.3 Who was buying

Citizen Lab's 2014 scan of Hacking Team RCS servers named 21 suspected current or former government users: Azerbaijan, Colombia, Egypt, Ethiopia, Hungary, Italy, Kazakhstan, Korea, Malaysia, Mexico, Morocco, Nigeria, Oman, Panama, Poland, Saudi Arabia, Sudan, Thailand, Turkey, the UAE and Uzbekistan [16] (**Confirmed**). Hacking Team marketed RCS as sold only to governments and as untraceable [16]. The 2015 leak confirmed Ethiopia, Sudan, Saudi Arabia and Kazakhstan as clients, along with every country Citizen Lab had earlier identified [25] (**Confirmed**).

The US government is the other buyer in the book's account. On the official side, Michael Daniel wrote in April 2014 that disclosure is in the national interest in the majority of cases while defending limited withholding [110], and Tom Bossert said in December 2017 that the government discloses about 90 percent of the vulnerabilities it finds [71] (**Confirmed** that they said so). The reviewer Jean Navedo summarizes the book as describing US agencies as the top buyers in the early black market [6] (**Reported**). No primary opened for this study puts a figure on US purchases.

Part 4: Operation Aurora and Google's turn

4.1 What Google disclosed

On 12 January 2010 Google said it had detected, in mid-December 2009, a targeted attack on its corporate infrastructure originating from China, and that intellectual property was stolen [85] (**Confirmed**). It said at least twenty other large companies in Internet, finance, technology, media and chemical sectors had been targeted the same way. A primary goal was the Gmail accounts of Chinese human rights activists, but only two accounts appear to have been accessed, and that access was limited to account information and subject lines [85] (**Confirmed**). Google said it would stop censoring Google.cn, and on 22 March 2010 it redirected Search, News and Images to Google.com.hk [85] [92] (**Confirmed**).

On 21 January 2010 Secretary of State Clinton, in her Internet Freedom speech, asked the Chinese authorities for a thorough and transparent review of the intrusions [90] (**Confirmed**).

4.2 The exploit and the fix

The browser bug was CVE-2010-0249, an Internet Explorer use-after-free (CWE-416, NVD CVSS 3.1 score 8.8), exploited in the wild during Aurora and published by NVD on 15 January 2010 [86] (**Confirmed**). Microsoft Security Advisory 979352 came out on 14 January. Version 1.1 on 15 January reflected the investigation of limited targeted attacks and added Data Execution Prevention to the mitigating factors; version 1.2 on 20 January reflected the changing nature of the attacks [87] (**Confirmed**). MS10-002, a cumulative IE update, fixed it on 21 January, seven days after the advisory, noting public disclosure and limited attacks [88] [87] (**Confirmed**). CISA added CVE-2010-0249 to KEV on 20 May 2026, more than sixteen years later [22] (**Confirmed**).

4.3 What the press added

Wired, quoting McAfee's Alperovitch, reported that the attacks appeared to begin on 15 December 2009 and stopped on 4 January 2010 when the command servers shut down. McAfee named the operation after a folder name in the malware's build paths, and at least 34 companies were reportedly targeted [89] (**Reported**). The same piece described encrypted shellcode and downloads, a covert channel posing as SSL, command servers in Illinois, Texas and Taiwan, iDefense's finding that source-code repositories were targeted, Symantec's identification of Hydraq on 11 January, and Adobe's discovery on 2 January that it had also been targeted [89] (**Reported**; Adobe's own post was not opened).

4.4 Attribution in ATT&CK

ATT&CK describes `G0066` Elderwood as a suspected Chinese espionage group reportedly responsible for the 2009 Google intrusion [96] (**Confirmed** that ATT&CK says so). Its software `S0203` Hydraq, also known as Aurora, 9002 RAT and McRat, was first used by Elderwood in Aurora and possibly later by APT17 (`G0025`); Axiom (`G0001`) is also listed [97] (**Confirmed**). There is no ATT&CK campaign object for Aurora [81]. Elderwood's place among China-attributed groups is set out in China-Attributed Threat Actors.

4.5 From Aurora to Project Zero

Google's posts show a sequence: the 2010 bounties [91] [93], warnings to users targeted by state-sponsored attackers from 5 June 2012 [94], and Project Zero on 15 July 2014, announced on the grounds that zero-day use against activists and for industrial espionage needs to stop [95] (**Confirmed**). None of those posts names Aurora as the cause, and the Project Zero post cites 2014 FireEye and Kaspersky research instead [95]. Reading the sequence as Aurora's legacy is this study's inference (**Inferred**).

Howard records a critics' claim that the book credits Morgan Marquis-Boire with saving the day for Google in Aurora. Howard says the book does not claim this and calls him integral to the investigation [5] (**Reported**).

Part 5: the Equation group and the Shadow Brokers

5.1 Equation, as Kaspersky described it

In February 2015 Kaspersky named the Equation group: earliest samples compiled in 2002, some command-and-control domains registered as early as 1996, a module that reprogrammed hard-drive firmware from more than a dozen brands, and two zero-days in the Fanny worm that were later found in Stuxnet, which Fanny used first [49] (**Confirmed**). Kaspersky names no government [49]. The Stuxnet side of this belongs to STUXNET.md; briefly, ATT&CK dates Stuxnet components to November 2008 [98], Kaspersky linked Stuxnet's Resource 207 to Flame in 2012 [100] (**Reported** as the vendor's kinship claim), and the LNK flaw CVE-2010-2568 entered KEV on 15 September 2022 [22].

5.2 The 2016 dump and the firewall fixes

A group calling itself the Shadow Brokers appeared on 13 August 2016 claiming to hold Equation Group files. It released a free PGP-encrypted archive of about 300 MB of firewall exploits and tools, including BANANAUSURPER, BLATSTING and BUZZDIRECTION, and offered a second encrypted archive for auction. The newest timestamps in the free set date to October 2013 [50] (**Confirmed**).

Kaspersky found 347 RC5 and RC6 implementations in the leak that are functionally identical to Equation code, down to subtracting 0x61C88647 instead of adding 0x9E3779B9, and stated high confidence that the

tools are related to Equation malware. It said it could not determine who leaked them or how [50] (**Confirmed** as Kaspersky's assessment).

Vendors moved within days. Cisco was alerted on 15 August and on 17 August published CVE-2016-6366, an ASA SNMP buffer overflow rated CVSS 8.5 (CWE-119) that needs the SNMP community string; the advisory says the exploit was publicly disclosed by the alleged Shadow Brokers group, and end-of-life PIX and FWSM devices get no fix [51] (**Confirmed**). Cisco named EXTRABACON (CVE-2016-6366), EPICBANANA (CVE-2016-6367, fixed since ASA 8.4(3)) and JETPLOW, a persistent implant of EPICBANANA, addressed BENIGNCERTAIN against legacy PIX on 19 August, and in April 2017 said it was analysing the new files [52] (**Confirmed**). Fortinet's FG-IR-16-023 (CVE-2016-6909) covers a cookie-parser overflow in FortiOS 4.3.8 and below; the advisory does not mention the leak and credits an SCRT researcher who reported the bug in August 2012 [53] (**Confirmed**; any tie to the dump is not checked). KEV lists CVE-2016-6366 and CVE-2016-6367, both added 24 May 2022; CVE-2016-6909 is not in KEV [23] (**Confirmed**).

5.3 The 2014 Kaspersky detection

Kaspersky's own investigation describes a September 2014 detection on a US user's home computer: a 7z archive holding Equation malware, apparent source code and four documents with classification markings. Kaspersky says the CEO ordered it deleted and that the data did not leave its network. The report does not mention the Shadow Brokers [54] (**Confirmed** as Kaspersky's account). No source opened links that detection to the leak.

5.4 The 2017 releases

A public mirror of the decrypted first auction archive was created on GitHub on 8 April 2017, according to repository metadata [58] (**Confirmed** for the date; the Shadow Brokers' own post was not opened). The Windows archive followed. The FBI affidavit says Microsoft patched CVE-2017-0144 on 14 March 2017 and that the Shadow Brokers released an exploit for it the next month, on 15 April 2017 [57]; the mirror of the decrypted archives was created at 11:41 UTC on 14 April 2017, so the release fell on 14 April US time [59] (**Confirmed**). That mirror lists three decrypted archives named odd, swift and windows [59]. Their contents were not checked, so this study says only that the release had a folder named swift.

On 15 April MSRC published its triage. MS17-010 addresses EternalBlue, EternalChampion, EternalRomance and EternalSynergy. MS10-061 addresses EmeraldThread, MS09-050 EducatedScholar, MS08-067 EclipsedWing and MS14-068 EskimoRoll. ErraticGopher was fixed before Vista (CVE-2017-8461 was added on 13 June 2017). EnglishmanDentist, EsteemAudit and ExplodingCan do not reproduce on supported platforms [60] (**Confirmed**). The post does not say where the March fix came from [60].

5.5 Who the Shadow Brokers were

No record opened for this study charges anyone as the Shadow Brokers or officially attributes them. The library's NOTABLE_INCIDENTS.md says "possibly Russian GRU or insider (never formally charged)" [55]; no primary in this pass supports the GRU part (**Reported**, and flagged in Part 10.4). The DOJ pages on the Pho and Martin cases were behind a bot check and were not opened, so no tie between those cases and the leak is stated.

The NSA origin of the tools rests on Microsoft's statement [67] and the publisher's framing of the book [2] (**Reported**). The US government briefing on WannaCry declined to name the tools' source [71]. The ATT&CK `G0020` Equation page names no software and does not mention the Shadow Brokers, the NSA or EternalBlue

[114] (**Confirmed**). United States-Attributed Threat Actors grades the wider attribution record for Equation and the leaks.

5.6 Buckeye had the tools first

Symantec reports that Buckeye (APT3, ATT&CK `G0022`) used a DoublePulsar variant delivered by a tool it calls Bemstour from at least March 2016, more than a year before the Shadow Brokers' Windows release. Bemstour exploited CVE-2019-0703, then a zero-day, and CVE-2017-0143. CVE-2019-0703 was reported in September 2018 and patched on 12 March 2019. Symantec says how Buckeye obtained the tools remains unknown [117] (**Confirmed** as Symantec's account). The ATT&CK `G0022` page carries the alias Buckeye but does not mention DoublePulsar, Bemstour or CVE-2019-0703 [115] (**Confirmed**). KEV added CVE-2019-0703 on 23 May 2022 [22].

Part 6: EternalBlue and WannaCry

6.1 The bug

MS17-010 (KB4013389), rated Critical, shipped on 14 March 2017. It fixes five SMBv1 remote code execution bugs (CVE-2017-0143, -0144, -0145, -0146, -0148) and one information disclosure (CVE-2017-0147), and marks all six as neither publicly disclosed nor exploited at release. The workaround is to disable SMBv1. Windows XP and Server 2003 are not in the table, and the bulletin credits no reporter [56] (**Confirmed**).

NVD describes CVE-2017-0144, the bug EternalBlue exploits, as SMBv1 server remote code execution via crafted packets in Vista SP2 through Windows 10 1607 and Server 2016, with CVSS v3.1 8.8 and v2 9.3 [61] (**Confirmed**). NVD and the CISA-ADP record on CVE.org give no CWE (NVD-CWE-noinfo) for CVE-2017-0143 to 0147; only CVE-2017-0148 carries CWE-20 [61] [62] (**Confirmed**). This study therefore assigns no CWE to EternalBlue.

6.2 From dump to worm

The FBI affidavit in the Park Jin Hyok case lays out the chain. A RiskSense analyst published research on the exploit on 18 and 21 April 2017, and RiskSense released reverse-engineered code on GitHub on 9 May 2017 for penetration testers [57] (**Demonstrated**: a public reproduction existed three days before WannaCry; the RiskSense repository itself was not opened). BAE Systems reported that at least part of that code was likely duplicated into WannaCry Version 2 [57] (**Confirmed** that the affidavit says so). A North Korean IP address visited the RiskSense researcher's blog on several dates [57] (**Confirmed** that the affidavit says so).

WannaCry was not new in May. Citing Symantec, the affidavit says Version 0 ran in February 2017 and Version 1 from March to April 2017, both spreading with stolen credentials; Version 2 added the SMB worm on 12 May [57] (**Confirmed** for the affidavit; the Symantec post returns 404, so the Symantec part is **Reported** through the affidavit). Kaspersky reported that Google's Neel Mehta flagged code shared between a February 2017 WannaCry sample and a February 2015 Lazarus sample, called a false flag improbable, and asked for independent checks [70] (**Confirmed**).

6.3 How it ran

Cisco Talos describes the worm scanning TCP 445, exploiting with ETERNALBLUE and using the DOUBLEPULSAR backdoor to run on the new host. It creates the service mssecsvc2.0, encrypts with tasksche.exe (RSA 2048), drops tor.exe for command and control, deletes shadow copies with WMIC and vssadmin, and uses attrib and icacls [63] (**Confirmed**). US-CERT TA17-132A adds probing of UDP 137 and 138 and TCP 139 and 445, and a ransom of about 0.1781 BTC (about USD 300) per open-source reporting [64] (**Confirmed** for the alert).

Marcus Hutchins registered the unregistered domain the sample queried, and a hosts-file test confirmed that registration halted new encryption. He judged the check a badly designed anti-analysis measure, not a deliberate kill switch [65] (**Confirmed** as his account). Talos says Cisco Umbrella first saw the kill-switch domain at 07:24 UTC [63]; Hutchins puts the campaign start at about 8 AM UTC from Umbrella data [65]. The two figures are given as each source states them. TA17-132A advises against blocking the kill-switch domain [64].

On 13 May Microsoft shipped fixes for out-of-support Windows XP, Windows 8 and Server 2003, with the Defender signature Ransom:Win32/WannaCrypt [66] (**Confirmed**). On 14 May Microsoft's president, Brad Smith, wrote that WannaCry used exploits stolen from the NSA, likened the theft to Tomahawk missiles, criticized government stockpiling and renewed the call for a Digital Geneva Convention [67] (**Confirmed** as Microsoft's claim, not US government confirmation).

6.4 The damage

Measure	Figure	Source
Spread	Hundreds of thousands of computers in more than 150 countries (Europol and others)	[57]
Spread	At least 150 countries and about 300,000 computers	[69]
NHS trusts	At least 81 of 236 English trusts affected, 37 infected	[68]
NHS trusts	At least 80 of 236 affected, at least 37 infected; 1,220 diagnostic devices (from the NCA)	[57]
NHS primary care	603 primary-care and other NHS organisations infected, including 595 GP practices	[68]
NHS primary care	About 8 percent of GP practices and a third of secondary-care hospitals	[69]
Appointments	6,912 cancelled appointments identified; over 19,000 estimated	[68]
NHS cost	Over USD 112 million	[69]
Ransom	No NHS body paid [68]; victims who paid do not appear to have been able to decrypt [57]	[68] [57]

All rows are **Confirmed** as the source states them. The NAO found that the infected NHS bodies ran unpatched or unsupported Windows [68]. Version 2 spread untargeted, by LAN and random internet scanning [57].

6.5 Attribution and charges

On 19 December 2017 the United States publicly attributed WannaCry to North Korea, joined by the UK, Australia, Canada, New Zealand and Japan. Bossert called it careless and reckless, credited the researcher who found the kill switch, said Microsoft and Facebook had acted against the operators, and rejected blame on the NSA [71] (**Confirmed**). The UK said the NCSC judged it highly likely that the North Korean actors known as the Lazarus Group were responsible [72] (**Confirmed**). TA17-132A was revised on 7 June 2018 to add the North Korea attribution [64].

The complaint against Park Jin Hyok, filed 8 June 2018 in the Central District of California, charges conspiracy and wire-fraud conspiracy from 2 September 2014 to 3 August 2017. It ties Sony Pictures (2014), Bangladesh Bank (2016) and WannaCry to one set of operators that industry calls Lazarus Group, names Chosun Expo as a DPRK front, and traces ransom proceeds into Monero [57] (**Confirmed**; the public unsealing date is not checked). The December 2020 indictment of Jon Chang Hyok, Kim Il and Park Jin Hyok says they worked for Reconnaissance General Bureau units known as Lazarus Group and APT38, and its Overt Act 13 says they authored WannaCry Version 2 on or before 12 May 2017 [73] (**Confirmed**). ATT&CK lists `G0032` Lazarus Group as the only group using `S0366` WannaCry [79].

Part 7: NotPetya and Bad Rabbit (summary)

NotPetya's home is SANDWORM_OPERATIONS.md; this paragraph summarizes the zero-day thread only. Microsoft saw first infections arrive through the M.E.Doc updater (EzVit.exe) around 10:30 GMT on 27 June 2017, more than 12,500 machines hit in Ukraine and 64 more countries after that, spreading by credential theft, PsExec, WMIC, EternalBlue (CVE-2017-0144) and EternalRomance (CVE-2017-0145) before overwriting the MBR and clearing logs [74] (**Confirmed**). Talos documented backdoored M.E.Doc updates on 14 April, 15 May and 22 June 2017; the first shares a date with the Shadow Brokers dump, but no source links the two [118] (**Confirmed**). The GRU indictment says lateral movement used credential theft first and fell back to EternalBlue or EternalRomance only if both other methods failed, and puts losses near USD 1 billion across three named US victims, including about USD 400 million at FedEx's TNT Express and over USD 500 million at a US pharmaceutical maker [78] (**Confirmed**). ESET says the SMB exploit was used only against the local address space, and that non-Ukrainian victims had VPN links into Ukraine [119] (**Confirmed**). The US and UK attributed NotPetya to the Russian military on 15 February 2018 [76] [77], and six officers of GRU Unit 74455 (ATT&CK `G0034` Sandworm Team) were indicted in October 2020 [78] (**Confirmed**). Bad Rabbit (`S0606`, 2017) is also Sandworm software; its `T1210` procedure names EternalRomance [112] (**Confirmed**).

Crediting all of NotPetya's reach to the leaked exploit overstates it, since the exploit was one of two fallback spreaders beside credential theft [78] [119] (**Inferred**).

Part 8: Hacking Team, NSO Group and the spyware vendors

8.1 Hacking Team before the leak

Citizen Lab fingerprinted Hacking Team's Remote Control System (RCS) servers in February 2014 and named 21 suspected government users (Part 3.3) [16] (**Confirmed**). In June 2014 it attributed an Android RCS implant to Hacking Team, delivered as a trojanized Qatif Today news app in March 2014 and using CVE-2012-6422 for root. Leaked RCS 9 manuals, whose authenticity Citizen Lab did not verify, described scout agents, a build factory and operator roles [17] (**Confirmed** for the attribution).

8.2 The July 2015 leak

The breach became public on 5 July 2015 [18]. Citizen Lab says it was about 400 GB of emails, client files and financial documents, announced through the company's own compromised Twitter account [25] (**Confirmed**). WikiLeaks published more than 1 million searchable Hacking Team emails on 8 July [24] (**Confirmed**).

The leak carried live exploits. CERT/CC records Flash CVE-2015-5119 and CVE-2015-5122 as made public on 5 July 2015; VU#561288 credits discovery of CVE-2015-5119 to Hacking Team and notes proof-of-concept code found in the leak, and both notes say exploit code is public [18] [19] (**Confirmed**). NVD describes CVE-2015-5119, CVE-2015-5122 and CVE-2015-5123 as Flash use-after-free flaws (CWE-416) exploited in the wild in July 2015 [20] (**Confirmed**). Microsoft's MS15-077 fixed CVE-2015-2387 in ATMFD.DLL on 14 July 2015, an elevation-of-privilege bug publicly disclosed and exploited in limited targeted attacks; the bulletin does not name Hacking Team [21] (**Confirmed**; the link to the leak is not checked). KEV lists CVE-2015-5119 and CVE-2015-2387 from 3 March 2022 and CVE-2015-5122 and CVE-2015-5123 from 13 April 2022 [22] (**Confirmed**).

The leak also fed later research: Citizen Lab's 2016 Mansoor report used leaked NSO documentation found in the Hacking Team emails as part of its NSO attribution [13] (**Confirmed**). ATT&CK tracks `S0047` Hacking Team UEFI Rootkit with `T1542.001` System Firmware and `T1014` Rootkit [26] (**Confirmed**), and `S0182` FinFisher as another commercial surveillance tool [44] (**Confirmed** that the page exists; its technique set is not recorded here).

8.3 Trident, 2016

Ahmed Mansoor received SMS lures on 10 and 11 August 2016 on an iPhone 6 running iOS 9.3.3. Citizen Lab and Lookout found that the links led to the Trident chain: CVE-2016-4657 in WebKit, CVE-2016-4655 a kernel information leak, and CVE-2016-4656 kernel memory corruption, delivering NSO Group's Pegasus. Citizen Lab named the UAE government as the likely operator and linked the infrastructure to Stealth Falcon (`G0038`) [13] (**Confirmed**). Stealth Falcon's wider record is in Other State-Linked Threat Actors. Apple shipped iOS 9.3.5 on 25 August 2016, crediting Citizen Lab and Lookout, about 15 days from lure to patch [15] [13] (**Confirmed**). Lookout's analysis says Trident was present through iOS 9.3.4 and describes Pegasus intercepting messages and calls, stealing passwords and tracking location [14] (**Confirmed**). KEV added all three CVEs on 24 May 2022 [22] (**Confirmed**).

8.4 Mapping the customers, 2017 and 2018

Citizen Lab documented more than 76 NSO exploit-link SMS messages to Mexican journalists, lawyers and civil-society staff, and at least 21 to the minor son of journalist Carmen Aristegui; it found no conclusive evidence tying them to a specific Mexican agency [31] (**Confirmed**). Its Hide and Seek scan (August 2016 to August 2018) found 1,091 IP addresses, 1,014 domains and 36 Pegasus systems, with suspected infections in 45 countries, six of them (Bahrain, Kazakhstan, Mexico, Morocco, Saudi Arabia, the UAE) with prior links to spyware abuse; NSO disputed the list [32] (**Confirmed**). In October 2018 Citizen Lab assessed with high confidence that the Saudi activist Omar Abdulaziz, a Canadian permanent resident, was infected by an operator it calls KINGDOM and links to Saudi Arabia [33] (**Confirmed**). Amnesty reports that Pegasus was installed on the phone of Hatice Cengiz four days after Jamal Khashoggi's murder on 2 October 2018; NSO denied any link [37] (**Confirmed** as Amnesty's finding).

8.5 WhatsApp, 2019

CVE-2019-3568, published 14 May 2019, is a WhatsApp VOIP stack buffer overflow allowing remote code execution via crafted RTCP packets (CWE-122 and CWE-787); KEV added it on 19 April 2022 [27] (**Confirmed**). The Ninth Circuit records WhatsApp's allegation that NSO sent malicious code through WhatsApp servers to about 1,400 devices, and the October 2019 suit under the Computer Fraud and Abuse Act and California law (N.D. Cal. 4:19-cv-07123-PJH). On 8 November 2021 it affirmed the denial of NSO's foreign sovereign immunity defense [28] (**Confirmed**). The Supreme Court denied NSO's petition for certiorari (No. 21-1338) on 9 January 2023 [29] (**Confirmed**). Meta reports a jury verdict in May 2025 ordering NSO to pay damages [30]; the amounts were not on the page and the docket was not opened (**Reported**). Whether the book discusses CVE-2019-3568 was not checked.

8.6 Zero-click, 2020 and 2021

Citizen Lab found that 36 personal phones of Al Jazeera staff were hacked in July and August 2020 with a zero-click iMessage chain it calls KISMET, a zero-day against at least iOS 13.5.1. It attributed 18 phones to an operator it calls MONARCHY (Saudi Arabia) and 15 to SNEAKY KESTREL (the UAE) [34] (**Confirmed**).

Amnesty's Forensic Methodology Report, peer-reviewed by Citizen Lab, documents iMessage zero-click attacks from 2019 and a 2021 wave it calls Megalodon that compromised a fully patched iPhone 12 on iOS 14.6 in July 2021. Amnesty released the Mobile Verification Toolkit and about 700 Pegasus domains [35] (**Confirmed**). Forbidden Stories says at least 180 journalists were among the numbers selected in the Pegasus Project leak [36] (**Confirmed** as its count).

Citizen Lab examined a Saudi activist's phone in March 2021, and in a report of 13 September 2021 said it had captured FORCEDENTRY (CVE-2021-30860), a zero-click iMessage exploit, after forwarding the artifacts to Apple on 7 September [39]. It had been in use since at least February 2021, and Citizen Lab attributed it to NSO with high confidence on the basis of a CASCADEFAIL artifact and a setframed process [39] (**Confirmed**). Apple's iOS 14.8 fixed CVE-2021-30860 in CoreGraphics, credited to Citizen Lab, and CVE-2021-31010 in Core Telephony, credited to Citizen Lab and Google Project Zero, both flagged as possibly actively exploited [40] (**Confirmed**). Project Zero then showed that FORCEDENTRY used a fake .gif to reach CoreGraphics' JBIG2 decoder, an integer overflow to get an unbounded canvas, and more than 70,000 segment commands to build a small computer out of logic operations; it judged NSO's capability comparable to a handful of nation states [41] (**Confirmed**). CVE-2021-30860 entered KEV on its first day, 3 November 2021, with CWE-20 and CWE-190; NVD lists CWE-190 [22] (**Confirmed**).

FORCEDENTRY's place in that year's record is set out in The Year 2021 in Intrusions.

Apple sued NSO Group and its parent on 23 November 2021, seeking a permanent injunction, pledging USD 10 million plus any damages to surveillance research, and saying its servers were not hacked in the FORCEDENTRY attacks [42] (**Confirmed**).

8.7 Candiru

Citizen Lab, working with Microsoft, exposed Candiru (now Saito Tech Ltd.). Microsoft patched the Windows privilege escalations CVE-2021-31979 and CVE-2021-33771 on 13 July 2021. Citizen Lab counted at least 100 victims in ten countries and more than 750 Candiru-linked websites; both CVEs entered KEV on 3 November 2021 [38] (**Confirmed**).

8.8 The Bezos phone

Graham's review says the book's claim that the Saudis hacked Jeff Bezos's phone with a zero-day is unfounded [7]. In January 2020 he argued that the FTI forensic report never decrypted the WhatsApp video it called an encrypted downloader, although the key should have been in the phone backup, so the report shows an unknown rather than evidence [9] (**Reported**). The FTI report and the UN statement on it could not be opened, so this study takes no position.

Part 9: Baltimore, 2019, and the EternalBlue dispute

This study is the home for the Baltimore reporting dispute because it is a dispute about the book's author and the book's text.

The original New York Times story by Perlroth and Shane, dated 25 May 2019, tied the Baltimore ransomware attack to the NSA-built EternalBlue. The NYT page could not be opened; this rests on Robert Graham's and Wikipedia's descriptions [8] [10] (**Reported**).

The court record tells a narrower story. The Robbinhood indictment (US v. Gholinejad, E.D.N.C. 4:24-cr-00016, filed 4 April 2024) says a conspirator held unauthorized access to Baltimore's networks from about 3 to 7 May 2019 and deployed Robbinhood about 7 May with a Bitcoin ransom demand. It describes generic hacking tools and administrator accounts and names no EternalBlue, SMB or NSA tool [108] (**Confirmed**). DOJ's plea release of 27 May 2025 says Baltimore lost more than USD 19 million and hundreds of computers were taken offline [109] (**Confirmed**). The library's `S0400` RobbinHood page carries no `T1210` mapping, while WannaCry and NotPetya both do [81] (**Confirmed**).

The reviewers differ on what the book did with this. Graham says the book concedes that the Baltimore ransomware did not spread via EternalBlue, but defends the story as broadly true and calls the point a technical detail [7], and he argues that the claim, repeated by hundreds of outlets, became accepted history [8] (**Reported**). Wikipedia describes the book's treatment as a recantation [10] (**Reported**). Howard reads the book as saying only that Microsoft analysts found EternalBlue evidence on Baltimore networks, not that the gang used it, while allowing that she may have implied use, and says the critics' item falls short of the accusation [5] (**Reported**).

What the record supports: the indictment describes the intrusion without EternalBlue [108]. That absence qualifies the original reporting but does not prove a negative (**Inferred**).

Part 10: the government record and the book's critics

10.1 The equities process

The White House said on 28 April 2014 that the government had no prior knowledge of Heartbleed and that disclosure is in the national interest in the majority of cases, while defending limited withholding [110] (**Confirmed**). The Vulnerabilities Equities Policy charter of 15 November 2017 sets a presumption of disclosure absent a demonstrable, overriding interest, names the NSA as the VEP Executive Secretariat, says the Equities Review Board meets monthly, calls for an annual report, and notes that partner nondisclosure agreements can constrain disclosure [103] (**Confirmed**). Bossert's 90 percent figure (Part 3.3) is the government's own number [71].

10.2 Sanctions and export controls

The Commerce Department's final rule 2021-24123 (86 FR 60759) added NSO Group and Candiru (Israel), Positive Technologies (Russia) and Computer Security Initiative Consultancy PTE. LTD. (Singapore) to the Entity List effective 4 November 2021 under EAR 744.11(b) [45] (**Confirmed**). It states that NSO and Candiru supplied spyware to foreign governments that targeted officials, journalists, businesspeople, activists, academics and embassy workers, and that the other two were listed for trafficking in cyber exploits; license policy is a presumption of denial with no license exceptions [46] (**Confirmed**).

Executive Order 14093, signed 27 March 2023 and published 30 March (88 FR 18957), bars US government use of commercial spyware that poses risks to national security [47] (**Confirmed**). On 5 March 2024 Treasury's OFAC designated Intellexa founder Tal Dilian, one other individual and five entities (Intellexa S.A., Intellexa Limited, Cytrox AD, Cytrox Holdings ZRT and Thalestris Limited) under EO 13694 as amended, citing the Predator spyware and its zero-click delivery and referencing EO 14093 [48] (**Confirmed**).

10.3 Later events in the book's period

The reviews mention Russian and Iranian attacks only in general terms [6]; the events below are the primary record for that period, not a list of what the book covers.

- **Shamoon.** ATT&CK `S0140` is a wiper first used by the Cutting Sword of Justice in 2012, with Shamoon 2 in 2016 and Shamoon 3 in 2018; the page does not name the victim [102] (**Confirmed**). Victim details were not opened. The Shamoon record sits with the Iran-attributed groups in Iran-Attributed Threat Actors.
- **Russian targeting of US infrastructure.** DHS and FBI TA18-074A says Russian government actors targeted energy, nuclear, water, aviation and critical manufacturing through staging targets since at least March 2016, and cites Dragonfly (`G0035`) [104] (**Confirmed**). Dragonfly's record is in Russia-Attributed Threat Actors.
- **The 2020 election.** The election infrastructure councils, through CISA, called the 3 November 2020 election the most secure in American history and said there was no evidence any voting system was compromised [105] (**Confirmed**).
- **SolarWinds.** CISA ED 21-01 ordered agencies to act on the Orion compromise, and its 15 April 2021 update attributes it to Russia's SVR [106]; ATT&CK tracks it as campaign `C0024` by APT29 (`G0016`) with SUNBURST (`S0559`) [107] (**Confirmed**). Home: SOLARWINDS_SUNBURST.md.

10.4 What the critics said, and what the record settles

Graham's review of 27 February 2021 says the errors would be unforgivable in investigative journalism but less so in a memoir. He argues that the "God mode" framing overstates zero-days, citing the Verizon 2020 DBIR's finding that they are rarely used in breaches; faults missing disclosure history and a political narrative; and allows that real market detail is present but buried [7] (**Reported**).

Howard works through nine critic-alleged errors: Aitel's NSA title, the Stuxnet zero-day count, the EternalBlue theft date, conflating bugs, backdoors and exploits, the NSA controlling and losing the market, the framing of self-modifying malware, Charlie Miller's family move, Marquis-Boire and Aurora, and Baltimore and EternalBlue. He concedes the Charlie Miller item was wrong but non-essential, treats items one to six as interpretation, rejects the Marquis-Boire item and says the Baltimore item falls short; he suggests some criticism reflected misogyny, and recommends the book but not for the Canon Hall of Fame [5] (**Reported**).

Two other Canon reviewers differ: Helen Patton recommends Hall of Fame status, noting both praise and criticism without evaluating it, and Larry Pesce considers the reporting reasonably accurate and the technical errors outside the narrative [5] (**Reported**). Navedo critiques a Eurocentric framing with little on Russia, China and Iran after Stuxnet, finds two policy proposals unrealistic (compulsory federal service for IT graduates; exclusive NSA purchase of exploits under NDA), and identifies no specific factual errors [6] (**Reported**).

Critic item	What the primary record in this study shows	Grade
EternalBlue theft date	The record dates the public leaks (13 August 2016, 14 April 2017) [50] [57] but not when the tools left NSA control	Inferred (unresolved)
Stuxnet zero-day count	Not checked here; home is STUXNET.md	not checked
Marquis-Boire and Aurora	No primary opened names him in Aurora	not checked
Baltimore and EternalBlue	The indictment names no EternalBlue, SMB or NSA tool [108]	Confirmed (absence); Inferred (meaning)
NSA origin of the tools	Microsoft says so [67]; the US briefing declined to name a source [71]	Reported
Bezos phone and a zero-day	The FTI report could not be opened [9]	not checked

10.5 Library corrections

These defects in the library were found while building this study and are routed to the library lane, not fixed here.

- NOTABLE_INCIDENTS.md attributes Aurora to APT10 and Comment Crew (Unit 61398) and says 30 or more companies and Gmail data. The record says Elderwood and Hydraq, at least twenty companies per Google, and only two accounts with account information and subject lines [55] [85] [96] [97].
- NOTABLE_INCIDENTS.md gives WannaCry as "$4-8B", "327 Bitcoin" and "200,000+" with no source; Treasury gives about 300,000 computers and over USD 112 million in NHS costs [55] [69].
- NOTABLE_INCIDENTS.md says the Shadow Brokers were possibly the Russian GRU; no primary opened supports that [55].
- CVE_REFERENCE.md gives CVE-2017-0144 a CVSS v2 of 8.1, CWE-119 and "XP through Server 2016"; NVD gives v2 9.3, no CWE, and Vista SP2 through Server 2016 [61].
- MALWARE_FAMILIES.md maps WannaCry to `T1190`; the live `S0366` page does not [79].

Part 11: the defender view

11.1 Exposure windows

Interval	Days	Sources
Aurora advisory 979352 to MS10-002	7	[87] [88]
Mansoor lure to iOS 9.3.5	about 15	[13] [15]
MS17-010 to the Shadow Brokers' Windows release	31	[56] [60]
Windows release to WannaCry Version 2	28	[57]
MS17-010 to WannaCry Version 2	59	[57]
RiskSense public code to WannaCry Version 2	3	[57]
MS17-010 to NotPetya	105	[56] [74]

All are **Confirmed** from the dated sources. The 1,794-day gap between MS17-010 and CVE-2017-0144's KEV entry reflects KEV's launch in late 2021, not defender patch latency (**Inferred**) [22].

11.2 KEV entries for the events in this study

CVE	Event	KEV added	Source
CVE-2010-0249	Aurora IE flaw	2026-05-20	[22]
CVE-2008-4250	MS08-067 (EclipsedWing)	2026-05-20	[22] [23]
CVE-2015-5119, CVE-2015-2387	Hacking Team leak	2022-03-03	[22]
CVE-2015-5122, CVE-2015-5123	Hacking Team leak	2022-04-13	[22]
CVE-2016-4655, -4656, -4657	Trident	2022-05-24	[22]
CVE-2016-6366, CVE-2016-6367	Shadow Brokers firewall exploits	2022-05-24	[23]
CVE-2017-0143	MS17-010	2021-11-03	[22]
CVE-2017-0144, -0145	EternalBlue, EternalRomance	2022-02-10	[22]
CVE-2017-0146	MS17-010	2022-03-25	[22]
CVE-2017-0148	MS17-010	2022-04-06	[22]
CVE-2017-0147	MS17-010	2022-05-24	[22]
CVE-2017-7269	ExplodingCan	2021-11-03	[23]
CVE-2014-6324	MS14-068 (EskimoRoll)	2022-03-25	[23]
CVE-2019-0703	Bemstour	2022-05-23	[22]
CVE-2019-3568	WhatsApp	2022-04-19	[27]
CVE-2014-0160	Heartbleed	2022-05-04	[22]
CVE-2021-30860	FORCEDENTRY	2021-11-03	[22]
CVE-2021-31979, CVE-2021-33771	Candiru	2021-11-03	[38]

All six MS17-010 CVEs are marked with known ransomware campaign use [22] (**Confirmed**). CVE-2016-6909 (Fortinet) is not in KEV [23].

11.3 What the sources tell defenders to do

- **Patch and remove SMBv1.** MS17-010's workaround is to disable SMBv1 [56]; TA17-132A says patch, disable SMBv1, block the ports at the boundary and keep offline backups [64]. SMBv1 is not installed by default from Windows 10 1709 onward, and Server 2019 and Windows 11 ship without it [120] (**Confirmed**). The ATT&CK `T1210` page lists mitigations including `M1051` Update Software and `M1042` Disable or Remove Feature or Program [80].
- **Do not block the kill switch.** TA17-132A advises against blocking the WannaCry kill-switch domain [64].
- **Watch the update channel.** NotPetya came through a trusted vendor's updater on three dates [118]; treat update servers as an attack path.
- **Expect credentials, not just exploits.** NotPetya used PsExec, WMI and a modified Mimikatz [75]; WannaCry Versions 0 and 1 spread with stolen credentials [57]. Patching alone would not have stopped either (**Inferred**).

- **Keep end-of-life gear off the network.** Cisco shipped no fix for end-of-life PIX and FWSM [51]; the NHS bodies infected by WannaCry ran unpatched or unsupported Windows [68].
- **Use the mobile tooling that exists.** Amnesty's Mobile Verification Toolkit and Pegasus domain list [35], and fast installation of iOS security releases such as 9.3.5 and 14.8 [15] [40], are the practical defences the record shows.
- **Patched bugs did the widest damage.** The worm-scale incidents in Parts 6 and 7 used SMB bugs patched weeks or months earlier [56] [57] [74] (**Inferred** from the Confirmed dates); the targeted spyware in Part 8 used zero-days.

Part 12: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 (Enterprise, Mobile and ICS), CAPEC, CWE and D3FEND. Every identifier was checked against a live ATT&CK page opened for this study or the library's own data files [81] [82] [83]; identifiers that could not be checked are left out. Rows marked Inferred are this study's analytic mappings and appear on no ATT&CK page.

12.1 Objects

Object	ATT&CK id	Library page	Relationship in this study
Elderwood	G0066	/mitre/groups/G0066.md	Reportedly responsible for Aurora [96]
Hydraq (Aurora, 9002 RAT, McRat)	S0203	/mitre/software/S0203.md	First used by Elderwood in Aurora [97]
Axiom	G0001	/mitre/groups/G0001.md	Listed on the Hydraq page [97]
APT17	G0025	/mitre/groups/G0025.md	Possibly used Hydraq later [97]
Equation	G0020	/mitre/groups/G0020.md	Kaspersky's 2015 report and the 2016 dump analysis [49] [50]; the ATT&CK page does not mention the Shadow Brokers [114]
APT3 (Buckeye)	G0022	/mitre/groups/G0022.md	Used a DoublePulsar variant from March 2016 per Symantec [117]; not on the ATT&CK page [115]
Lazarus Group	G0032	/mitre/groups/G0032.md	The only group listed for WannaCry [79]; named in the charges [57] [73]
WannaCry	S0366	/mitre/software/S0366.md	16 Enterprise and 2 ICS techniques [79]
Sandworm Team	G0034	/mitre/groups/G0034.md	GRU Unit 74455; NotPetya via M.E.Doc [113] [78]
NotPetya	S0368	/mitre/software/S0368.md	14 Enterprise and 3 ICS techniques [111]
Bad Rabbit	S0606	/mitre/software/S0606.md	Sandworm software; EternalRomance under T1210 [112]
Olympic Destroyer	S0365	/mitre/software/S0365.md	Sandworm software [113]; home is SANDWORM_OPERATIONS.md
RobbinHood	S0400	/mitre/software/S0400.md	Baltimore 2019; no T1210 mapping [81]
Shamoon	S0140	/mitre/software/S0140.md	Wiper first used in 2012 [102]
Hacking Team UEFI Rootkit	S0047	/mitre/software/S0047.md	Hacking Team tooling [26]
FinFisher	S0182	/mitre/software/S0182.md	Commercial surveillance software [44]
Stealth Falcon	G0038	/mitre/groups/G0038.md	Infrastructure linked to the Mansoor attack per Citizen Lab [13]
Pegasus for iOS	Mobile S0289	none (no generated mobile software page)	15 Mobile techniques; page does not mention Trident [43]
Pegasus for Android (Chrysaor)	Mobile S0316	none	Listed by ATT&CK [43]

Object	ATT&CK id	Library page	Relationship in this study
Stuxnet, Flame, Duqu	`S0603`, `S0143`, `S0038`	/mitre/software/S0603.md, /mitre/software/S0143.md, /mitre/software/S0038.md	Home is STUXNET.md [98] [101]
Dragonfly	`G0035`	/mitre/groups/G0035.md	Cited by TA18-074A [104]
SolarWinds Compromise	`C0024`	/mitre/campaigns/C0024.md	APT29 (`G0016`, /mitre/groups/G0016.md), SUNBURST (`S0559`, /mitre/software/S0559.md) [107]
Campaigns for WannaCry, NotPetya, the leaks	none	none	ATT&CK has no campaign or software object for EternalBlue, EternalRomance, DoublePulsar, Bemstour, WannaCry, NotPetya or the Shadow Brokers leak [81]

12.2 ATT&CK Enterprise techniques (62)

ID	Name	Tactic	Where it appears	Sources
T1210	Exploitation of Remote Services	Lateral Movement	WannaCry EternalBlue, 12 May 2017; NotPetya EternalBlue and EternalRomance, 27 June 2017; Bad Rabbit EternalRomance, 2017	[79] [63] [111] [74] [112]
T1570	Lateral Tool Transfer	Lateral Movement	WannaCry, 12 May 2017	[79]
T1563.002	RDP Hijacking	Lateral Movement	WannaCry	[79]
T1021.002	SMB/Windows Admin Shares	Lateral Movement	NotPetya, PsExec over ADMIN$	[111] [74]
T1543.003	Windows Service	Persistence, Privilege Escalation	WannaCry service mssecsvc2.0; Hydraq	[79] [63] [97]
T1486	Data Encrypted for Impact	Impact	WannaCry; NotPetya (library page); RobbinHood, Baltimore 2019; Shamoon	[79] [63] [81] [102]
T1490	Inhibit System Recovery	Impact	WannaCry shadow-copy deletion; RobbinHood	[79] [63] [81]
T1489	Service Stop	Impact	WannaCry; RobbinHood	[79] [81]
T1529	System Shutdown/Reboot	Impact	NotPetya; Shamoon	[111] [102]
T1485	Data Destruction	Impact	Shamoon, 2012	[102]
T1561.002	Disk Structure Wipe	Impact	Shamoon	[102]
T1047	Windows Management Instrumentation	Execution	WannaCry WMIC; NotPetya WMI	[79] [63] [111] [75]
T1569.002	Service Execution	Execution	NotPetya PsExec; Hydraq	[111] [74] [97]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	NotPetya	[111]
T1059.003	Windows Command Shell	Execution	RobbinHood, Baltimore 2019	[81]
T1203	Exploitation for Client Execution	Execution	Elderwood, Aurora 2009; Flash CVE-2015-5119/5122/5123, July 2015 (Inferred for Flash)	[96] [86] [20]
T1204.001	Malicious Link	Execution	Elderwood	[96]
T1204.002	Malicious File	Execution	Elderwood	[96]
T1129	Shared Modules	Execution	Hydraq	[97]
T1189	Drive-by Compromise	Initial Access	Elderwood, Aurora; Bad Rabbit watering holes	[96] [112]
T1566.001	Spearphishing Attachment	Initial Access	Elderwood	[96]
T1566.002	Spearphishing Link	Initial Access	Elderwood	[96]
T1195.002	Compromise Software Supply Chain	Initial Access	Sandworm, NotPetya via M.E.Doc, 27 June 2017	[113] [78] [118]

ID	Name	Tactic	Where it appears	Sources
T1078.003	Local Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	NotPetya	[111]
T1003.001	LSASS Memory	Credential Access	NotPetya, modified Mimikatz	[111] [75]
T1016	System Network Configuration Discovery	Discovery	WannaCry; Hydraq	[79] [97]
T1018	Remote System Discovery	Discovery	WannaCry	[79]
T1083	File and Directory Discovery	Discovery	WannaCry; NotPetya; Hydraq	[79] [111] [97]
T1120	Peripheral Device Discovery	Discovery	WannaCry; Equation	[79] [114]
T1518.001	Security Software Discovery	Discovery	NotPetya	[111]
T1057	Process Discovery	Discovery	Hydraq	[97]
T1012	Query Registry	Discovery	Hydraq	[97]
T1082	System Information Discovery	Discovery	Hydraq	[97]
T1007	System Service Discovery	Discovery	Hydraq	[97]
T1222.001	Windows Permissions	Defense Impairment	WannaCry icacls	[79] [63]
T1685.005	Clear Windows Event Logs	Defense Impairment	NotPetya cleared logs; Hydraq	[111] [74] [97]
T1685	Disable or Modify Tools	Defense Impairment	RobbinHood	[81]
T1112	Modify Registry	Defense Impairment, Persistence	Hydraq	[97]
T1564.001	Hidden Files and Directories	Stealth	WannaCry attrib	[79] [63]
T1564.005	Hidden File System	Stealth	Equation	[114]
T1480.001	Environmental Keying	Stealth	Equation	[114]
T1542.002	Component Firmware	Stealth, Persistence	Equation; hard-drive firmware module per Kaspersky	[114] [49]
T1542.001	System Firmware	Stealth, Persistence	Hacking Team UEFI Rootkit	[26]
T1014	Rootkit	Stealth	Hacking Team UEFI Rootkit	[26]
T1218.011	Rundll32	Stealth	NotPetya	[111]
T1036	Masquerading	Stealth	NotPetya	[111]
T1027	Obfuscated Files or Information	Stealth	Hydraq	[97]

ID	Name	Tactic	Where it appears	Sources
T1027.002	Software Packing	Stealth	Elderwood	[96]
T1027.013	Encrypted/Encoded File	Stealth	Elderwood	[96]
T1070.004	File Deletion	Stealth	Hydraq	[97]
T1070.005	Network Share Connection Removal	Stealth	RobbinHood	[81]
T1134	Access Token Manipulation	Stealth, Privilege Escalation	Hydraq	[97]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	CVE-2015-2387, July 2015; Candiru CVE-2021-31979 and CVE-2021-33771, July 2021 (Inferred)	[21] [38]
T1090.003	Multi-hop Proxy	Command and Control	WannaCry tor.exe	[79] [63]
T1573.002	Asymmetric Cryptography	Command and Control	WannaCry	[79]
T1573.001	Symmetric Cryptography	Command and Control	Hydraq	[97]
T1105	Ingress Tool Transfer	Command and Control	Elderwood; Hydraq	[96] [97]
T1048	Exfiltration Over Alternative Protocol	Exfiltration	Hydraq	[97]
T1005	Data from Local System	Collection	Hydraq	[97]
T1113	Screen Capture	Collection	Hydraq	[97]
T1588.005	Exploits	Resource Development	Lazarus reuse of the RiskSense code; Buckeye's DoublePulsar variant (Inferred)	[57] [117]
T1587.004	Exploits	Resource Development	Equation (Inferred)	[49] [117]

`T1588.005` sits under Obtain Capabilities and `T1587.004` under Develop Capabilities; ATT&CK names both sub-techniques Exploits. Hydraq rows come from the `S0203` software object, which ATT&CK ties to Aurora's first use [97]; they describe the malware, not a dated Aurora report. WannaCry is not mapped to `T1190` by ATT&CK [79].

12.3 ATT&CK Mobile techniques (Pegasus for iOS, `S0289`)

ATT&CK maps these 15 Mobile techniques to `S0289` [43]. The page does not mention Trident or its CVEs, so the event column names the ATT&CK record only. The library has no generated Mobile technique pages, so the ids are not linked.

ID	Name	Tactic	Source
T1429	Audio Capture	Collection	[43]
T1645	Compromise Client Software Binary	Persistence	[43]
T1456	Drive-By Compromise	Initial Access	[43]
T1658	Exploitation for Client Execution	Execution	[43]
T1664	Exploitation for Initial Access	Initial Access	[43]

ID	Name	Tactic	Source
T1404	Exploitation for Privilege Escalation	Privilege Escalation	[43]
T1430	Location Tracking	Collection, Discovery	[43]
T1644	Out of Band Data	Command and Control	[43]
T1660	Phishing	Initial Access	[43]
T1636.002	Call Log	Collection	[43]
T1636.003	Contact List	Collection	[43]
T1636.004	SMS Messages	Collection	[43]
T1409	Stored Application Data	Collection	[43]
T1426	System Information Discovery	Discovery	[43]
T1421	System Network Connections Discovery	Discovery	[43]

12.4 ATT&CK for ICS techniques

ID	Name	Tactic	Where it appears	Sources
T0866	Exploitation of Remote Services	Initial Access, Lateral Movement	WannaCry; NotPetya	[79] [111]
T0867	Lateral Tool Transfer	Lateral Movement	WannaCry; NotPetya	[79] [111]
T0828	Loss of Productivity and Revenue	Impact	NotPetya	[111]

The library has no ICS technique pages, so these ids are not linked; they are layered in the ICS layer of Part 12.7.

12.5 Vulnerabilities, CWE and CAPEC

CVE	Event	CWE (NVD unless noted)	CAPEC (library data)	Sources
CVE-2010-0249	Aurora	CWE-416	none for CWE-416; CAPEC-163 Spear Phishing through the Elderwood `T1566.001` and `T1566.002` profiles	[86] [81] [82]
CVE-2015-5119, -5122, -5123	Hacking Team Flash	CWE-416	none	[20] [82]
CVE-2016-4656, -4657	Trident	CWE-787 (CVE-2016-4655: no CWE)	none for CWE-787	[116] [82]
CVE-2016-6366	EXTRABACON	CWE-119 (Cisco advisory)	not mapped	[51]
CVE-2017-0143 to -0147	MS17-010, including EternalBlue	none (NVD-CWE-noinfo); the KEV catalog lists CWE-20 (CWE-200 for -0147)	none	[61] [62] [22]
CVE-2017-0148	MS17-010	CWE-20	CWE-20 maps to 51 CAPEC entries in the library, too generic to pin	[61] [82]
CVE-2019-3568	WhatsApp	CWE-122, CWE-787	none for CWE-787	[27] [82]
CVE-2021-30860	FORCEDENTRY	CWE-190 (KEV also lists CWE-20)	not pinned	[22]
CVE-2014-0160	Heartbleed	CWE-125	CAPEC-540 Overread Buffers	[116] [82]
none (technique)	NotPetya M.E.Doc update	CWE-494	CAPEC-186 Malicious Software Update, via `T1195.002` (the tie to NotPetya is Inferred)	[82] [118]

The Elderwood phishing path links to CAPEC-163. In the library's data, `T1210`, `T1203`, `T1189` and `T1486` carry no CAPEC [82]. No CWE is recorded for CVE-2015-2387 or the Candiru CVEs in the sources opened, so none is given.

12.6 ATT&CK mitigations and D3FEND countermeasures

The live `T1210` page lists mitigations `M1048`, `M1042`, `M1050`, `M1030`, `M1026`, `M1019`, `M1051` and `M1016` [80]. In the library's D3FEND data, patching appears only through `M1051` and `M1042` on `T1210`; D3FEND Software Update does not list `T1210` [83].

ATT&CK technique	D3FEND countermeasures in the library	Event	Sources
`T1210` (16 mapped)	Network Traffic Filtering (D3-NTF), Network Traffic Signature Analysis (D3-NTSA), Connection Attempt Analysis (D3-CAA), Protocol Metadata Anomaly Detection, Process Segment Execution Prevention, Segment Address Offset Randomization	WannaCry, NotPetya, Bad Rabbit	[83]
`T1486` (11 mapped)	Restore File (D3-RF), Decoy File (D3-DF), File Integrity Monitoring (D3-FIM)	WannaCry, NotPetya, RobbinHood	[83]

ATT&CK technique	D3FEND countermeasures in the library	Event	Sources
`T1195.002`	Software Update, Software Inventory, Asset Vulnerability Enumeration, Restore Software	NotPetya via M.E.Doc	[83]
`T1561.002`	Disk Partitioning	Shamoon	[83]
Aurora techniques (`T1189`, `T1203`, `T1566`)	Process Segment Execution Prevention (D3-PSEP, matching the DEP mitigation added on 15 January 2010 [87]), Segment Address Offset Randomization (D3-SAOR), URL Reputation Analysis (D3-URA), URL Analysis (D3-UA), Network Traffic Signature Analysis (D3-NTSA), Email Filtering (D3-EF)	Aurora	[81] [83]

12.7 Navigator layers

- Enterprise: `navigator/library-layers/zero-day-market-events.json` (open in Navigator), domain `enterprise-attack`, ATT&CK version 20 [84], the 62 techniques of Part 12.2, each shown under all of its tactics with a comment naming the event and the source numbers of this study. Scores: 100 for a technique an ATT&CK page ties to an event in this study, 75 for an ATT&CK software or group record related to the event but not dated to it (Hydraq, Equation, the Hacking Team rootkit, Shamoon), 40 for an Inferred mapping.
- ICS: `navigator/case-studies/zero-day-market-events-ics.json` (open in Navigator), domain `ics-attack`, the 3 ATT&CK for ICS techniques of Part 12.4 at score 100, each with a comment naming WannaCry or NotPetya and the source numbers.
- Mobile: the 15 Mobile ids of Part 12.3 are listed but not layered. The library's validator accepts `mobile-attack` layers, but the Navigator page has no case-study section for Mobile layers, and the `S0289` page ties none of the techniques to a dated event.
- Both layers are listed on the Navigator layers page.

Cross-cutting themes

- **The leak was faster than the market.** A million-dollar iPhone chain was a private sale [12] [13]. The Hacking Team and Shadow Brokers leaks made exploits free, and they were exploited in the wild within weeks [18] [20] [57]. The largest harm in this record came from leaked tools, not purchased ones (**Inferred** from the Confirmed dates).
- **Patched is not protected.** MS17-010 predated the leak by 31 days and WannaCry by 59 [56] [57]. The NHS bodies that were infected ran unpatched or unsupported Windows [68]. The policy debate is about stockpiles; the damage was about patch latency (**Inferred**).
- **Evidence beat assertion in the spyware story.** The strongest record on NSO is forensic: captured exploits, Apple's credits, Project Zero's analysis and the Ninth Circuit [13] [39] [40] [41] [28]. Price figures remain **Reported** [13] [14]; customer and operator lists rest on Citizen Lab's scans and the leak itself and are **Confirmed** [16] [25] [32].
- **Overstated and understated.** Overstated: the leaked exploit as the cause of every outbreak. Baltimore's court record names no EternalBlue [108], NotPetya fell back to it only after credential theft [78], and Graham cites the DBIR's finding that zero-days are rarely used in breaches [7] (**Reported** for the DBIR

point). Understated: how ordinary the spread paths were, from stolen credentials in early WannaCry [57] to PsExec, WMI and Mimikatz in NotPetya [75], and how long old bugs stay useful, with CVE-2010-0249 and MS08-067 entering KEV only in 2026 [22].

- **ATT&CK describes behavior, not provenance.** No ATT&CK object carries EternalBlue, DoublePulsar or the Shadow Brokers [81] [114]. The lineage from leak to worm lives in court records and vendor reports, not in the technique matrix, so defenders who want to track exploit provenance need both.
- **The policy record grew teeth.** It moved from a 2014 blog post [110] to a 2017 charter [103], 2021 export controls [45], a 2023 executive order [47] and 2024 sanctions [48]. Most steps followed a documented abuse in the technical record (**Inferred**).

Sources

#	Source	URL	Opened	Grade
1	Open Library, ISBN 9781635576054 catalog record	https://openlibrary.org/isbn/9781635576054.json	3 Nov 2026	Confirmed
2	Bloomsbury, This Is How They Tell Me the World Ends (publisher page)	`www.bloomsbury.com/us/this-is-how-they-tell-me-the-world-ends-9781635576061/` (not linked: the host returns 403 to automated link checks)	3 Nov 2026	Confirmed (catalog facts); Reported (framing, award)
3	Financial Times, 2021 Business Book of the Year winner	https://ig.ft.com/sites/business-book-award/books/2021/winner/this-is-how-they-tell-me-the-world-ends-by-nicole-perlroth/	3 Nov 2026	Confirmed
4	TeamStarWolf, CYBERSECURITY_BOOK_LIST.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/CYBERSECURITY_BOOK_LIST.md	3 Nov 2026	Confirmed
5	Rick Howard and others, Cybersecurity Canon review	https://cybercanon.org/this-is-how-they-tell-me-the-world-ends/	3 Nov 2026	Reported
6	Jean Navedo, American University SIS book review	`www.american.edu/sis/centers/security-technology/this-is-how-they-tell-me-the-world-ends-book-review.cfm` (not linked: the host returns 403 to automated link checks)	3 Nov 2026	Reported
7	Robert Graham, Errata Security, review of the book (27 Feb 2021)	https://blog.erratasec.com/2021/02/review-perlroths-book-on-cyberarms.html	3 Nov 2026	Reported
8	Robert Graham, Errata Security, on EternalBlue and Baltimore (28 Feb 2021)	https://blog.erratasec.com/2021/02/we-are-living-in-1984-eternalblue.html	3 Nov 2026	Reported
9	Robert Graham, Errata Security, on decrypting WhatsApp media (28 Jan 2020)	https://blog.erratasec.com/2020/01/how-to-decrypt-whatsapp-end-to-end.html	3 Nov 2026	Reported
10	Wikipedia, 2019 Baltimore ransomware attack	https://en.wikipedia.org/wiki/2019_Baltimore_ransomware_attack	3 Nov 2026	Reported
11	Zero Day Initiative, About	https://www.zerodayinitiative.com/about/	3 Nov 2026	Confirmed
12	Zerodium, iOS 9 bounty page (archived 25 Oct 2015)	http://web.archive.org/web/20151025142008/http://www.zerodium.com:80/ios9.html	3 Nov 2026	Confirmed
13	Citizen Lab, The Million Dollar Dissident (24 Aug 2016)	https://citizenlab.ca/2016/08/million-dollar-dissident-iphone-zero-day-nso-group-uae/	3 Nov 2026	Confirmed; Reported (prices)
14	Lookout, Pegasus technical analysis	https://info.lookout.com/rs/051-ESQ-475/images/lookout-pegasus-technical-analysis.pdf	3 Nov 2026	Confirmed; Reported (prices)
15	Apple, About the security content of iOS 9.3.5	https://support.apple.com/en-us/HT207107	3 Nov 2026	Confirmed
16	Citizen Lab, Mapping Hacking Team's Untraceable Spyware (Feb 2014)	https://citizenlab.ca/2014/02/mapping-hacking-teams-untraceable-spyware/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
17	Citizen Lab, Hacking Team's Tradecraft and Android Implant (Jun 2014)	https://citizenlab.ca/2014/06/backdoor-hacking-teams-tradecraft-android-implant/	3 Nov 2026	Confirmed
18	CERT/CC, VU#561288 (CVE-2015-5119)	https://www.kb.cert.org/vuls/id/561288	3 Nov 2026	Confirmed
19	CERT/CC, VU#338736 (CVE-2015-5122)	https://www.kb.cert.org/vuls/id/338736	3 Nov 2026	Confirmed
20	NVD, CVE-2015-5119	https://nvd.nist.gov/vuln/detail/CVE-2015-5119	3 Nov 2026	Confirmed
21	Microsoft, MS15-077	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2015/ms15-077	3 Nov 2026	Confirmed
22	CISA, Known Exploited Vulnerabilities catalog (JSON feed, catalogVersion 2026.11.03)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	3 Nov 2026	Confirmed
23	CISA, Known Exploited Vulnerabilities catalog (web)	https://www.cisa.gov/known-exploited-vulnerabilities-catalog	3 Nov 2026	Confirmed
24	WikiLeaks, Hacking Team emails	https://wikileaks.org/hackingteam/emails/	3 Nov 2026	Confirmed
25	Citizen Lab, Hacking Team leak highlights Citizen Lab research	https://citizenlab.ca/2015/07/hacking-team-leak-highlights-citizen-lab-research/	3 Nov 2026	Confirmed
26	MITRE ATT&CK, S0047 Hacking Team UEFI Rootkit	https://attack.mitre.org/software/S0047/	3 Nov 2026	Confirmed
27	NVD, CVE-2019-3568	https://nvd.nist.gov/vuln/detail/CVE-2019-3568	3 Nov 2026	Confirmed
28	US Court of Appeals for the Ninth Circuit, WhatsApp v. NSO Group, No. 20-16408 (8 Nov 2021)	https://cdn.ca9.uscourts.gov/datastore/opinions/2021/11/08/20-16408.pdf	3 Nov 2026	Confirmed
29	Supreme Court docket No. 21-1338	https://www.supremecourt.gov/docket/docketfiles/html/public/21-1338.html	3 Nov 2026	Confirmed
30	Meta, Winning the fight against spyware merchant NSO (May 2025)	https://about.fb.com/news/2025/05/winning-the-fight-against-spyware-merchant-nso/	3 Nov 2026	Reported
31	Citizen Lab, Reckless Exploit (Mexico, Jun 2017)	https://citizenlab.ca/2017/06/reckless-exploit-mexico-nso/	3 Nov 2026	Confirmed
32	Citizen Lab, Hide and Seek (Sep 2018)	https://citizenlab.ca/2018/09/hide-and-seek-tracking-nso-groups-pegasus-spyware-to-operations-in-45-countries/	3 Nov 2026	Confirmed
33	Citizen Lab, The Kingdom Came to Canada (Oct 2018)	https://citizenlab.ca/2018/10/the-kingdom-came-to-canada-how-saudi-linked-digital-espionage-reached-canadian-soil/	3 Nov 2026	Confirmed
34	Citizen Lab, The Great iPwn (Dec 2020)	https://citizenlab.ca/2020/12/the-great-ipwn-journalists-hacked-with-suspected-nso-group-imessage-zero-click-exploit/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
35	Amnesty International, Forensic Methodology Report (Jul 2021)	https://www.amnesty.org/en/latest/research/2021/07/forensic-methodology-report-how-to-catch-nso-groups-pegasus/	3 Nov 2026	Confirmed
36	Forbidden Stories, The Pegasus Project	https://forbiddenstories.org/case/the-pegasus-project/	3 Nov 2026	Confirmed
37	Amnesty International, The Pegasus Project press release (Jul 2021)	https://www.amnesty.org/en/latest/press-release/2021/07/the-pegasus-project/	3 Nov 2026	Confirmed
38	Citizen Lab, Hooking Candiru (Jul 2021)	https://citizenlab.ca/2021/07/hooking-candiru-another-mercenary-spyware-vendor-comes-into-focus/	3 Nov 2026	Confirmed
39	Citizen Lab, FORCEDENTRY (Sep 2021)	https://citizenlab.ca/2021/09/forcedentry-nso-group-imessage-zero-click-exploit-captured-in-the-wild/	3 Nov 2026	Confirmed
40	Apple, About the security content of iOS 14.8	https://support.apple.com/en-us/HT212807	3 Nov 2026	Confirmed
41	Google Project Zero, A deep dive into an NSO zero-click iMessage exploit (Dec 2021)	https://projectzero.google/2021/12/a-deep-dive-into-nso-zero-click.html	3 Nov 2026	Confirmed
42	Apple Newsroom, Apple sues NSO Group (23 Nov 2021)	https://www.apple.com/newsroom/2021/11/apple-sues-nso-group-to-curb-the-abuse-of-state-sponsored-spyware/	3 Nov 2026	Confirmed
43	MITRE ATT&CK, S0289 Pegasus for iOS	https://attack.mitre.org/software/S0289/	3 Nov 2026	Confirmed
44	MITRE ATT&CK, S0182 FinFisher	https://attack.mitre.org/software/S0182/	3 Nov 2026	Confirmed
45	Federal Register, 2021-24123, Addition of Certain Entities to the Entity List	https://www.federalregister.gov/documents/2021/11/04/2021-24123/addition-of-certain-entities-to-the-entity-list	3 Nov 2026	Confirmed
46	Federal Register, 2021-24123 full text	https://www.federalregister.gov/documents/full_text/html/2021/11/04/2021-24123.html	3 Nov 2026	Confirmed
47	Federal Register, Executive Order 14093	https://www.federalregister.gov/documents/2023/03/30/2023-06730/prohibition-on-use-by-the-united-states-government-of-commercial-spyware-that-poses-risks-to	3 Nov 2026	Confirmed
48	US Treasury, press release jy2155 (5 Mar 2024)	https://home.treasury.gov/news/press-releases/jy2155	3 Nov 2026	Confirmed
49	Kaspersky, Equation: The Death Star of Malware Galaxy (16 Feb 2015)	https://securelist.com/equation-the-death-star-of-malware-galaxy/68750/	3 Nov 2026	Confirmed
50	Kaspersky, The Equation giveaway (Aug 2016)	https://securelist.com/the-equation-giveaway/75812/	3 Nov 2026	Confirmed
51	Cisco, cisco-sa-20160817-asa-snmp (CVE-2016-6366)	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20160817-asa-snmp	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
52	Cisco, Shadow Brokers blog post	https://blogs.cisco.com/security/shadow-brokers	3 Nov 2026	Confirmed
53	Fortinet, FG-IR-16-023 (CVE-2016-6909)	https://www.fortiguard.com/psirt/FG-IR-16-023	3 Nov 2026	Confirmed
54	Kaspersky, Investigation report for the September 2014 Equation malware detection incident in the US (16 Nov 2017)	https://securelist.com/investigation-report-for-the-september-2014-equation-malware-detection-incident-in-the-us/83210/	3 Nov 2026	Confirmed
55	TeamStarWolf, NOTABLE_INCIDENTS.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/NOTABLE_INCIDENTS.md	3 Nov 2026	Reported (library text)
56	Microsoft, MS17-010	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010	3 Nov 2026	Confirmed
57	US DOJ, criminal complaint and FBI affidavit, United States v. Park Jin Hyok (C.D. Cal., filed 8 Jun 2018)	https://www.justice.gov/opa/press-release/file/1092091/download	3 Nov 2026	Confirmed; Demonstrated (RiskSense code)
58	GitHub repository metadata for a public mirror of the first auction archive (creation date only)	not linked: the repository hosts leaked exploit code	3 Nov 2026	Confirmed (date only)
59	GitHub repository metadata and description for a public mirror of the April 2017 archives	not linked: the repository hosts leaked exploit code	3 Nov 2026	Confirmed (date and folder names only)
60	Microsoft MSRC, Protecting customers and evaluating risk (Apr 2017)	https://www.microsoft.com/en-us/msrc/blog/2017/04/protecting-customers-and-evaluating-risk	3 Nov 2026	Confirmed
61	NVD, CVE-2017-0144	https://nvd.nist.gov/vuln/detail/CVE-2017-0144	3 Nov 2026	Confirmed
62	CVE.org record API, CVE-2017-0144	https://cveawg.mitre.org/api/cve/CVE-2017-0144	3 Nov 2026	Confirmed
63	Cisco Talos, WannaCry (May 2017)	https://blog.talosintelligence.com/wannacry/	3 Nov 2026	Confirmed
64	US-CERT, TA17-132A Indicators Associated With WannaCry Ransomware	https://www.cisa.gov/news-events/alerts/2017/05/12/indicators-associated-wannacry-ransomware	3 Nov 2026	Confirmed
65	Marcus Hutchins, How to Accidentally Stop a Global Cyber Attacks	`www.malwaretech.com/2017/05/how-to-accidentally-stop-a-global-cyber-attacks.html` (not linked: the host returns 403 to automated link checks)	3 Nov 2026	Confirmed
66	Microsoft MSRC, Customer guidance for WannaCrypt attacks	https://www.microsoft.com/en-us/msrc/blog/2017/05/customer-guidance-for-wannacrypt-attacks	3 Nov 2026	Confirmed
67	Microsoft On the Issues, Brad Smith, The need for urgent collective action (14 May 2017)	https://blogs.microsoft.com/on-the-issues/2017/05/14/need-urgent-collective-action-keep-people-safe-online-lessons-last-weeks-cyberattack/	3 Nov 2026	Confirmed (Microsoft's claim); Reported (NSA origin)

#	Source	URL	Opened	Grade
68	UK National Audit Office, Investigation: WannaCry cyber attack and the NHS	https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/	3 Nov 2026	Confirmed
69	US Treasury, press release sm774 (13 Sep 2019)	https://home.treasury.gov/news/press-releases/sm774	3 Nov 2026	Confirmed
70	Kaspersky, WannaCry and Lazarus Group: the missing link?	https://securelist.com/wannacry-and-lazarus-group-the-missing-link/78431/	3 Nov 2026	Confirmed
71	White House (archived), press briefing on the attribution of WannaCry to North Korea (19 Dec 2017)	https://trumpwhitehouse.archives.gov/briefings-statements/press-briefing-on-the-attribution-of-the-wannacry-malware-attack-to-north-korea-121917/	3 Nov 2026	Confirmed
72	UK government, Foreign Office Minister condemns North Korean actor for WannaCry attacks	https://www.gov.uk/government/news/foreign-office-minister-condemns-north-korean-actor-for-wannacry-attacks	3 Nov 2026	Confirmed
73	US DOJ, indictment of Jon Chang Hyok, Kim Il and Park Jin Hyok (returned 8 Dec 2020)	https://www.justice.gov/opa/press-release/file/1367701/download	3 Nov 2026	Confirmed
74	Microsoft Security, New ransomware, old techniques: Petya adds worm capabilities (27 Jun 2017)	https://www.microsoft.com/en-us/security/blog/2017/06/27/new-ransomware-old-techniques-petya-adds-worm-capabilities/	3 Nov 2026	Confirmed
75	US-CERT, TA17-181A Petya Ransomware	https://www.cisa.gov/news-events/alerts/2017/07/01/petya-ransomware	3 Nov 2026	Confirmed
76	White House (archived), Statement from the Press Secretary (15 Feb 2018)	https://trumpwhitehouse.archives.gov/briefings-statements/statement-press-secretary-25/	3 Nov 2026	Confirmed
77	UK government, Foreign Office Minister condemns Russia for NotPetya attacks	https://www.gov.uk/government/news/foreign-office-minister-condemns-russia-for-notpetya-attacks	3 Nov 2026	Confirmed
78	US DOJ, indictment of six GRU Unit 74455 officers (W.D. Pa., Oct 2020)	https://www.justice.gov/opa/press-release/file/1328521/download	3 Nov 2026	Confirmed
79	MITRE ATT&CK, S0366 WannaCry	https://attack.mitre.org/software/S0366/	3 Nov 2026	Confirmed
80	MITRE ATT&CK, T1210 Exploitation of Remote Services	https://attack.mitre.org/techniques/T1210/	3 Nov 2026	Confirmed
81	TeamStarWolf library ATT&CK data and generated pages (data/attack, mitre/)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	3 Nov 2026	Confirmed
82	TeamStarWolf library weakness data (CWE and CAPEC)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/weaknesses	3 Nov 2026	Confirmed
83	TeamStarWolf library technique_to_d3fend.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_to_d3fend.jsonl	3 Nov 2026	Confirmed
84	TeamStarWolf library scripts/validate_navigator.py (layer format)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/scripts/validate_navigator.py	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
85	Google, A new approach to China (12 Jan 2010)	https://googleblog.blogspot.com/2010/01/new-approach-to-china.html	3 Nov 2026	Confirmed
86	NVD, CVE-2010-0249	https://nvd.nist.gov/vuln/detail/CVE-2010-0249	3 Nov 2026	Confirmed
87	Microsoft Security Advisory 979352	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2010/979352	3 Nov 2026	Confirmed
88	Microsoft, MS10-002	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2010/ms10-002	3 Nov 2026	Confirmed
89	Wired, Operation Aurora (Jan 2010)	https://www.wired.com/2010/01/operation-aurora/	3 Nov 2026	Reported
90	US Department of State (archived), Secretary Clinton, Remarks on Internet Freedom (21 Jan 2010)	https://2009-2017.state.gov/secretary/20092013clinton/rm/2010/01/135519.htm	3 Nov 2026	Confirmed
91	Chromium Blog, Encouraging more Chromium security research (28 Jan 2010)	https://blog.chromium.org/2010/01/encouraging-more-chromium-security.html	3 Nov 2026	Confirmed
92	Google, A new approach to China: an update (22 Mar 2010)	https://googleblog.blogspot.com/2010/03/new-approach-to-china-update.html	3 Nov 2026	Confirmed
93	Google Online Security Blog, Rewarding web application security research (1 Nov 2010)	https://security.googleblog.com/2010/11/rewarding-web-application-security.html	3 Nov 2026	Confirmed
94	Google Online Security Blog, Security warnings for suspected state-sponsored attacks (5 Jun 2012)	https://security.googleblog.com/2012/06/security-warnings-for-suspected-state.html	3 Nov 2026	Confirmed
95	Google Project Zero, Announcing Project Zero (15 Jul 2014)	https://googleprojectzero.blogspot.com/2014/07/announcing-project-zero.html	3 Nov 2026	Confirmed
96	MITRE ATT&CK, G0066 Elderwood	https://attack.mitre.org/groups/G0066/	3 Nov 2026	Confirmed
97	MITRE ATT&CK, S0203 Hydraq	https://attack.mitre.org/software/S0203/	3 Nov 2026	Confirmed
98	MITRE ATT&CK, S0603 Stuxnet	https://attack.mitre.org/software/S0603/	3 Nov 2026	Confirmed
99	Kaspersky, The Flame: questions and answers (28 May 2012)	https://securelist.com/the-flame-questions-and-answers/34344/	3 Nov 2026	Confirmed; Reported (kinship)
100	Kaspersky, Back to Stuxnet: the missing link (11 Jun 2012)	https://securelist.com/back-to-stuxnet-the-missing-link/33174/	3 Nov 2026	Reported (vendor kinship claim)
101	MITRE ATT&CK, S0143 Flame	https://attack.mitre.org/software/S0143/	3 Nov 2026	Confirmed
102	MITRE ATT&CK, S0140 Shamoon	https://attack.mitre.org/software/S0140/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
103	White House (archived), Vulnerabilities Equities Policy and Process charter (15 Nov 2017)	https://trumpwhitehouse.archives.gov/sites/whitehouse.gov/files/images/External%20-%20Unclassified%20VEP%20Charter%20FINAL.PDF	3 Nov 2026	Confirmed
104	CISA, TA18-074A Russian Government Cyber Activity Targeting Energy and Other Critical Infrastructure Sectors	https://www.cisa.gov/news-events/alerts/2018/03/15/russian-government-cyber-activity-targeting-energy-and-other-critical-infrastructure-sectors	3 Nov 2026	Confirmed
105	CISA, Joint statement from the Elections Infrastructure Government Coordinating Council and Sector Coordinating Executive Committees (12 Nov 2020)	https://www.cisa.gov/news-events/news/joint-statement-elections-infrastructure-government-coordinating-council-election	3 Nov 2026	Confirmed
106	CISA, ED 21-01 Mitigate SolarWinds Orion Code Compromise	https://www.cisa.gov/news-events/directives/ed-21-01-mitigate-solarwinds-orion-code-compromise	3 Nov 2026	Confirmed
107	MITRE ATT&CK, C0024 SolarWinds Compromise	https://attack.mitre.org/campaigns/C0024/	3 Nov 2026	Confirmed
108	US DOJ, indictment, United States v. Gholinejad (E.D.N.C. 4:24-cr-00016, filed 4 Apr 2024)	https://www.justice.gov/opa/media/1401606/dl?inline	3 Nov 2026	Confirmed
109	US DOJ, Iranian man pleaded guilty for role in Robbinhood ransomware (27 May 2025)	https://www.justice.gov/opa/pr/iranian-man-pleaded-guilty-role-robbinhood-ransomware	3 Nov 2026	Confirmed
110	White House (archived), Michael Daniel, Heartbleed: Understanding When We Disclose Cyber Vulnerabilities (28 Apr 2014)	https://obamawhitehouse.archives.gov/blog/2014/04/28/heartbleed-understanding-when-we-disclose-cyber-vulnerabilities	3 Nov 2026	Confirmed
111	MITRE ATT&CK, S0368 NotPetya	https://attack.mitre.org/software/S0368/	3 Nov 2026	Confirmed
112	MITRE ATT&CK, S0606 Bad Rabbit	https://attack.mitre.org/software/S0606/	3 Nov 2026	Confirmed
113	MITRE ATT&CK, G0034 Sandworm Team	https://attack.mitre.org/groups/G0034/	3 Nov 2026	Confirmed
114	MITRE ATT&CK, G0020 Equation	https://attack.mitre.org/groups/G0020/	3 Nov 2026	Confirmed
115	MITRE ATT&CK, G0022 APT3	https://attack.mitre.org/groups/G0022/	3 Nov 2026	Confirmed
116	NVD CVE API 2.0 (CVE-2014-0160 and the other CWE lookups in Part 12.5)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2014-0160	3 Nov 2026	Confirmed
117	Symantec (security.com), Buckeye: Espionage outfit used Equation Group tools prior to Shadow Brokers leak	https://www.security.com/threat-intelligence/buckeye-windows-zero-day-exploit	3 Nov 2026	Confirmed
118	Cisco Talos, The MeDoc Connection	https://blog.talosintelligence.com/the-medoc-connection/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
119	ESET WeLiveSecurity, TeleBots are back: supply-chain attacks against Ukraine (30 Jun 2017)	https://www.welivesecurity.com/2017/06/30/telebots-back-supply-chain-attacks-against-ukraine/	3 Nov 2026	Confirmed
120	Microsoft Learn, SMBv1 is not installed by default in Windows 10 version 1709, Windows Server version 1709 and later versions	https://learn.microsoft.com/en-us/windows-server/storage/file-server/troubleshoot/smbv1-not-installed-by-default-in-windows	3 Nov 2026	Confirmed

Sources not opened, and therefore not cited for any fact: the book's text; the New York Times Baltimore story of 25 May 2019; the FTI report on the Bezos phone and the UN statement on it; the Shadow Brokers' own posts; the Symantec WannaCry post of 22 May 2017 (404); the RiskSense repository; the DOJ pages on the Pho and Martin cases (bot check); the WhatsApp v. NSO district docket; Adobe's 2010 post.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Cybersecurity Book List
- Notable Incidents
- Threat Actors
- Malware Families
- CVE Reference
- Vulnerability Management Reference
- Mobile Security Reference and the Mobile ATT&CK Atlas
- ATT&CK Software Reference
- Home studies for events summarized here: Stuxnet, SolarWinds and SUNBURST, 2019 to 2021, Sandworm Operations
- Related case studies: United States-Attributed Threat Actors, China-Attributed Threat Actors, Russia-Attributed Threat Actors, Iran-Attributed Threat Actors, Other State-Linked Threat Actors, The Year 2019 in Intrusions, The Year 2020 in Intrusions, The Year 2021 in Intrusions, APT41: The Public Record, Log4Shell
- Navigator layers, including this study's layers, zero-day-market-events.json and zero-day-market-events-ics.json

- MITRE pages: groups G0066, G0020, G0022, G0032, G0034, G0038; software S0203, S0366, S0368, S0606, S0400, S0140, S0047, S0182; campaign C0024; and the technique pages linked in Part 12.2
- CWE Reference, CAPEC Reference, D3FEND Reference
- All case studies